

Université Sultan Moulay Slimane
École Nationale des Sciences Appliquées de Khouribga

PROJET DE FIN D'ANNÉE

Département Réseau, Télécommunication et Cybersécurité
Spécialité : Ingénierie des Réseaux Intelligents et Cybersécurité
Option : Cybersécurité

Présenté par :
Chouaib LAREDJ

Laboratoire d'entreprise Zero Trust Simulation d'attaques et défense

Conception, mise en œuvre et évaluation de contrôles Zero Trust dans un laboratoire
d'entreprise hybride : simulation d'attaques et analyse avant/après

Encadrante : Dr JIHANE JEBRANE

Édition portfolio publique — octobre 2026
Captures privées et adresses du tailnet retirées

Année universitaire 2025–2026

Remerciements

Je tiens à exprimer ma profonde gratitude et mes sincères remerciements à mon encadrante pédagogique, **Dr Jihane JEBRANE**, pour son encadrement bienveillant, ses conseils méthodologiques avisés et son exigence scientifique tout au long de ce projet de fin d'année. Ses orientations ont été déterminantes pour mener à bien cette démarche d'ingénierie et d'expérimentation rigoureuse.

J'adresse également mes vifs remerciements au corps professoral et à la direction de **l'École Nationale des Sciences Appliquées de Khouribga** (ENSA Khouribga), au sein de l'Université Sultan Moulay Slimane, pour la qualité de la formation d'excellence dispensée au sein de la filière Ingénierie des Réseaux Intelligents et Cybersécurité.

Résumé

La migration des services vers le cloud et l'accès distant des collaborateurs rendent obsolète tout modèle de sécurité fondé sur la seule confiance périmétrique. Ce projet de fin d'année conçoit, déploie et évalue empiriquement un laboratoire d'entreprise hybride combinant six machines virtuelles sous Google Cloud Platform (VPC) et un poste Windows local interconnecté via un réseau superposé chiffré Tailscale (WireGuard).

L'infrastructure intègre une gestion centralisée des identités (Active Directory, Keycloak OIDC/MFA), une application métier Flask/PostgreSQL et une pile de supervision de sécurité (Sysmon, Wazuh SIEM/HIDS). À partir d'un état initial permissif (*Legacy*), une série de contrôles Zero Trust alignés sur le NIST SP 800-207 a été implémentée et mesurée : micro-segmentation réseau par règles ingress granulaires, séparation stricte des privilèges d'administration (RBAC), moindre privilège au niveau des données PostgreSQL, chiffrement cryptographique d'annuaire (LDAPS TLS 1.3) et réponse active automatisée Wazuh.

Les essais montrent une réduction de joignabilité de 8/8 à 0/8 couples cible-port TCP depuis la source attaquante étudiée, un refus administrateur pour le compte employé et le rejet de quatre opérations SQL sous le rôle applicatif (SQLSTATE 42501). Le parcours OTP et cinq alertes corrélées sont observés. La réponse active utilise un événement synthétique. Le 8 octobre, le poste distant atteint la racine du portail et ne joint pas directement la base, mais la découverte du domaine échoue : la continuité hybride reste partielle. Ces mesures portent sur les chemins testés et ne constituent pas une garantie globale de sécurité.

Mots-clés : Zero Trust, Micro-segmentation, Contrôle d'accès (RBAC), Architecture hybride, Wazuh.

Abstract

The migration of enterprise services to public clouds and the prevalence of remote work render traditional perimeter-based security architectures obsolete. This capstone engineering project designs, implements, and experimentally evaluates a hybrid Zero Trust enterprise laboratory combining six virtual machines hosted on Google Cloud Platform with an on-premises Windows workstation interconnected via a Tailscale WireGuard overlay.

The architecture integrates identity federation (Active Directory, Keycloak OIDC/MFA), a tiered web application (Flask, PostgreSQL), and unified security monitoring (Sysmon, Wazuh SIEM/HIDS). Transitioning from a permissive baseline, granular Zero Trust controls aligned with NIST SP 800-207 were enforced: network micro-segmentation, role-based access control (RBAC), database least privilege, directory encryption (LDAPS TLS 1.3), and automated active response.

The tested attacker source went from 8/8 reachable to 0/8 reachable TCP target-port pairs. Employee administrator access was denied and four SQL statements were rejected under the application role (`SQLSTATE 42501`). An OTP browser flow and five correlated alerts were observed. Active response used a synthetic event. On October 8 the remote workstation reached the portal root and could not connect directly to the database, but domain discovery failed. Hybrid continuity therefore remains partial; these results do not establish global protection or complete Zero Trust deployment.

Keywords: Zero Trust Architecture, Cloud Security, Micro-segmentation, Role-Based Access Control, Active Response.

Table des matières

Remerciements	i
Introduction générale	1
1 Contexte général et cadrage du projet	2
1.1 Cadre académique et compétences mobilisées	2
1.2 Présentation du projet	2
1.3 Besoin métier et exigences du laboratoire	3
1.4 Problématique et questions de recherche	3
1.5 Objectifs et critères de réussite	4
1.5.1 Construire une infrastructure explicable	4
1.5.2 Établir un état initial fonctionnel	4
1.5.3 Identifier les frontières de confiance	4
1.5.4 Préparer une comparaison reproductible	4
1.6 Hypothèses et méthode d'évaluation	5
1.7 Périmètre, contraintes et limites	5
1.8 Organisation et chronologie de la réalisation	5
2 État de l'art et fondements conceptuels	7
2.1 Confiance implicite et modèle périmétrique	7
2.2 Principes fondamentaux du Zero Trust et NIST SP 800-207	7
2.2.1 Les sept principes cardinaux (Core Tenets) du NIST SP 800-207 . .	8
2.2.2 Architecture logique : Découplage Plan de Contrôle et Plan de Données	9
2.3 Identité, authentification et autorisation	9
2.3.1 Annuaire Active Directory	9
2.3.2 LDAP, Kerberos et dépendances du domaine	9
2.3.3 Authentification applicative avec OIDC	10
2.3.4 MFA et contrôle des rôles	10
2.4 Segmentation et connectivité	10
2.4.1 Sous-réseaux et filtrage	10
2.4.2 Réseau overlay et routeur de sous-réseau	10
2.4.3 Administration par IAP	11
2.5 Télémétrie, SIEM et détection	11
2.6 Données et contrôle d'accès PostgreSQL	11

2.7	Simulation d'attaques et MITRE ATT&CK	11
2.8	Approches comparables et positionnement	12
3	Conception et architecture du laboratoire	14
3.1	Besoins et choix de conception	14
3.2	Inventaire et rôle de chaque machine	15
3.2.1	vm-ad : référentiel d'identité	16
3.2.2	vm-sysmon : poste de travail observé	17
3.2.3	vm-web : application et passerelle hybride	17
3.2.4	vm-db : dépôt des données métier	18
3.2.5	vm-keycloak : identité applicative	18
3.2.6	vm-wazuh : point d'observation	18
3.2.7	vm-attacker : source expérimentale	19
3.3	Topologie et frontières du laboratoire	20
3.4	Fonctionnement de l'architecture traditionnelle	20
3.4.1	Parcours du poste vers le domaine	20
3.4.2	Parcours d'une consultation métier	21
3.4.3	Place de Keycloak dans cet état	21
3.4.4	Chaîne d'observation	22
3.5	Pourquoi cet état reste fondé sur la confiance implicite	22
3.6	Protocole de vérification de l'architecture	22
4	Réalisation des phases 1 et 2 : infrastructure et services	23
4.1	Phase 1 : mise en place de l'infrastructure	23
4.1.1	Préparation sous VMware et migration	23
4.1.2	Infrastructure as Code et ressources déclarées	23
4.1.3	Organisation du VPC et sortie réseau	24
4.1.4	Pare-feu initial et accès IAP	24
4.1.5	Snapshots et points de restauration	25
4.2	Phase 2 : configuration des services	26
4.2.1	Active Directory : domaine et organisation	26
4.2.2	Poste Windows : DNS, jonction et instrumentation	27
4.2.3	PostgreSQL : données, rôles et connexions	27
4.2.4	Flask : portail métier et accès initial	28
4.2.5	Keycloak : préparation de la fédération	29
4.2.6	Wazuh : collecte et activité normale	29
4.2.7	Tailscale : routage hybride et retour des paquets	30
4.3	Difficultés rencontrées et interprétation	31
4.4	Bilan fonctionnel et préparation des preuves	32
5	Phase 3 : expérimentation offensive et diagnostic initial	33
5.1	Phase 3 : périmètre et méthode	33
5.2	Reconnaissance et joignabilité des services	33

5.3	Annuaire et mécanismes d'authentification	34
5.4	Accès direct aux données et chemin via le serveur web	34
5.5	Événements observés et limites des tests	34
5.6	Phase 3 applicative : essais S01 à S03 des 6 et 7 octobre	35
5.7	Synthèse de la surface de vulnérabilité initiale (État Legacy)	36
6	Phase 4 : durcissement Zero Trust, validation empirique et analyse comparative	38
6.1	Méthodologie d'évaluation et matrice globale des contrôles	38
6.2	Gouvernance des identités et contrôle d'accès applicatif	41
6.2.1	Authentification multifacteur (TOTP) et déconnexion sécurisée	41
6.2.2	Contrôle d'accès basé sur les rôles (RBAC) sur le portail métier	41
6.3	Micro-segmentation réseau intra-VPC et retrait de la confiance implicite	43
6.3.1	Architecture des tranches de filtrage granulaire	43
6.3.2	Preuve empirique de continuité des services autorisés	44
6.3.3	Validation des chemins réseau Wazuh sous micro-segmentation	44
6.3.4	Isolation réseau de la source hostile (S04-VPC)	45
6.4	Supervision de sécurité, détection SIEM et réponse active	46
6.4.1	Corrélation d'alertes applicatives (Règle Wazuh 100510)	46
6.4.2	Confinement dynamique automatisé par Wazuh Active Response	47
6.5	Campagnes de validation offensive et postulat de brèche (<i>Assume Breach</i>)	48
6.5.1	Campagne 1 : Ré-attaque intra-VPC et réduction de joignabilité	48
6.5.2	Campagne 2 : Évaluation du rayon d'action (<i>Blast Radius</i>)	49
6.5.3	Campagne 4 : Durcissement cryptographique de l'annuaire (LDAPS TLS 1.3 et retrait du port 389)	50
6.6	Évaluation de la connectivité hybride et limitations architecturales	52
6.7	Discussion critique et synthèse des gains d'ingénierie Zero Trust	53
6.7.1	Synthèse des contributions réalisées	53
6.7.2	Fiabilité opérationnelle et attribution des résultats	53
6.7.3	Limites opérationnelles de l'état gelé	54
	Conclusion générale	55
	Bibliographie	57
A	Cahier de recette et guide de reproduction	59
A.1	Registre des preuves de l'édition publique	59
A.2	Limites et recette de la réparation proposée	60
A.3	État opérationnel à la clôture du périmètre	60

Table des figures

3.1	Topologie logique du laboratoire hybride	20
3.2	Parcours métier de l'application Legacy	21
3.3	Chaîne d'observation Sysmon et Wazuh	22
4.1	Inventaire des instances du laboratoire	24
4.2	Plan d'adressage GCP	24
4.3	Configuration de la sortie réseau	24
4.4	Règles réseau initiales	24
4.5	Sortie horodatée de l'hôte vm-web dans la session distante	24
4.6	Domaine et organisation Active Directory	27
4.7	Appartenance des comptes aux groupes de rôle	27
4.8	Événement Sysmon local	27
4.9	Schéma et permissions de la base	28
4.10	Paramètres d'écoute PostgreSQL	28
4.11	Règles d'accès PostgreSQL	28
4.12	Configuration Flask examinée	28
4.13	Test local de la route employee	28
4.14	Fédération LDAP configurée dans Keycloak	29
4.15	Test de connexion de Keycloak vers LDAP	29
4.16	État des cinq agents Wazuh au 6 octobre 2026	30
4.17	Vue d'ensemble Wazuh au moment de la collecte	30
4.18	Wazuh : 736 résultats pour vm-ad dans la fenêtre de 24 heures affichée	30
4.19	Connexion reçue de vm-ad : agent 004, Kerberos et type réseau 3	30
4.20	Événement Security 4624 : connexion réussie sur vm-ad.corp.local	30
4.21	Règle 60106, Windows Logon Success, niveau 3 ; T1078 est un classement	30
4.22	Machines Tailscale présentes dans le tailnet	31
4.23	Routes de sous-réseau approuvées pour vm-web	31
4.24	Règles d'accès visibles pour le tag workstation	31
4.25	Adresse Tailscale de vm-web : adresse tailnet masquée, distincte de son adresse VPC	31
4.26	Adresse Tailscale du poste vm-sysmon : adresse tailnet masquée	31
5.1	S03 avant contrôle : la session employé accède à la configuration synthétique, le 6 octobre 2026	36

6.1	S02 : demande OTP pour lab-employee lors d'une nouvelle connexion, le 7 octobre 2026	41
6.2	S02 : accès métier après le parcours OTP, avec identité lab-employee et six enregistrements	41
6.3	Après déconnexion Flask et Keycloak, une route protégée redemande les identifiants	41
6.4	S03 après contrôle : refus HTTP 403 sur la route admin	42
6.5	Attribution directe du rôle portal-admin au compte carol.admin	42
6.6	S03 : page administrateur accessible au compte de test autorisé	42
6.7	Validation de la micro-segmentation : flux Web-Keycloak autorisés et refus inter-machines observés	44
6.8	Tests matriciels TCP vers le gestionnaire Wazuh sous micro-segmentation	44
6.9	S04 : règle GCP de refus, priorité 900, source 192.168.1.2/32 et huit ports TCP ; journalisation activée	45
6.10	S04 : résultats Nmap AD avant/après, le 7 octobre à 14 :35 et 14 :38 UTC ; cinq ports ouverts puis filtrés	45
6.11	Wazuh : cinq alertes indexées de la règle 100510, niveau 5, sur vm-web	46
6.12	Détail Wazuh : identité lab-employee, route admin et statut 403 dans l'événement JSON	46
6.13	Définition de la règle personnalisée Wazuh 100510 dans local_rules.xml	47
6.14	Inventaire des binaires de réponse active Wazuh sur l'agent vm-web	47
6.15	Validation de l'intégrité SQL sous compromission d'hôte (Assume Breach)	50
6.16	Génération et installation du certificat serveur LDAPS avec SAN FQDN sous PowerShell	51
6.17	Mise à jour du pare-feu GCP : retrait définitif du port TCP 389	51

Liste des tableaux

1.1	Objectifs et éléments permettant d'en juger la réalisation	4
2.1	Comparaison des approches dans le périmètre du projet	12
3.1	Placement et systèmes déclarés dans les sources du laboratoire	15
3.2	Correspondance architecturale entre les actifs du laboratoire, le NIST SP 800-207 et le modèle de maturité CISA	16
4.1	Inventaire des snapshots GCP observés le 5 octobre 2026	25
4.2	Difficultés de réalisation et vérifications associées	31
5.1	Matrice de synthèse des résultats de la phase 3	35
6.1	État des preuves et validation empirique des contrôles Zero Trust (7 octobre 2026)	40
6.2	Résultats du contrôle de rôle applicatif; heures UTC, octobre 2026	42
6.3	Tranches de micro-segmentation : état du 7 octobre après transition LDAPS; exception AD du 8 octobre décrite ensuite	43
6.4	Matrice comparative de joignabilité réseau avant/après durcissement Zero Trust	48

Liste des sigles et abréviations

Sigle	Signification	Rôle dans le projet
ACL	Access Control List	Politique de contrôle des accès réseau.
AD DS	Active Directory Domain Services	Annuaire du domaine et identités Windows.
CIDR	Classless Inter-Domain Routing	Notation des plages et masques réseau.
DNS	Domain Name System	Résolution des noms et découverte des services AD.
GCP	Google Cloud Platform	Hébergement des six serveurs du laboratoire.
GPO	Group Policy Object	Politique Windows ; son existence ne prouve pas un durcissement appliqué.
HTTP(S)	Hypertext Transfer Protocol (Secure)	Accès au portail et aux consoles web.
IaC	Infrastructure as Code	Description de l'infrastructure par Terraform.
IAM	Identity and Access Management	Gestion des identités et des autorisations.
IAP	Identity-Aware Proxy	Tunnel d'administration vers les VM GCP.
ICMP	Internet Control Message Protocol	Diagnostic réseau ; autorisé dans la règle initiale.
IP	Internet Protocol	Adressage des interfaces et routage.
IRIC	Ingénierie des Réseaux Intelligents et Cybersécurité	Filière de formation de l'auteur.
LDAP	Lightweight Directory Access Protocol	Consultation de l'annuaire et fédération Keycloak.
MFA	Multi-Factor Authentication	Authentification à plusieurs facteurs observée sur le parcours applicatif.

Liste des sigles et abréviations (suite)

Sigle	Signification	Rôle dans le projet
MTU	Maximum Transmission Unit	Taille des paquets ; enjeu du transport à travers le VPN.
NAT	Network Address Translation	Traduction d'adresses pour certains échanges réseau.
NIST	National Institute of Standards and Technology	Auteur du référentiel SP 800-207.
OIDC	OpenID Connect	Protocole d'authentification applicative.
OU	Organizational Unit	Organisation des objets Active Directory.
RBAC	Role-Based Access Control	Autorisation fondée sur les rôles.
RDP	Remote Desktop Protocol	Administration graphique des systèmes Windows.
SIEM	Security Information and Event Management	Centralisation et analyse de la télémétrie.
SMB	Server Message Block	Protocole Windows considéré dans les tests du laboratoire.
SNAT	Source Network Address Translation	Traduction de la source au passage du routeur de sous-réseau.
SQL	Structured Query Language	Requêtes et gestion des données PostgreSQL.
SSH	Secure Shell	Administration distante des VM Linux.
SSO	Single Sign-On	Authentification unique entre applications intégrées.
TCP/UDP	Transmission Control Protocol / User Datagram Protocol	Transports employés par les services et diagnostics.
TLS	Transport Layer Security	Protection des communications applicatives.
TOTP	Time-Based One-Time Password	Code temporaire utilisé sur le parcours OTP observé.
VM	Virtual Machine	Machine virtuelle locale ou cloud.
VPC	Virtual Private Cloud	Réseau privé logique du laboratoire GCP.
VPN	Virtual Private Network	Liaison chiffrée entre le poste local et le cloud.
ZTA	Zero Trust Architecture	Cadre architectural étudié.

Introduction générale

Les systèmes d'information d'entreprise associent des identités, des applications, des bases de données et des mécanismes de surveillance. Leur sécurité dépend des relations entre ces composants autant que de leur configuration individuelle. Une application sans contrôle d'accès peut exposer des informations même si son serveur n'est pas accessible directement depuis Internet. De même, un poste autorisé à rejoindre un réseau peut disposer d'une connectivité plus étendue que celle nécessaire à son activité.

L'évolution vers des environnements hybrides accentue cette difficulté : le poste de travail et les services ne partagent plus nécessairement le même site physique. Il faut garantir la communication utile tout en identifiant les accès excessifs. Le Zero Trust propose d'évaluer l'accès à une ressource sans accorder une confiance implicite à la seule localisation réseau de l'utilisateur ou du dispositif [1]. Ce principe constitue le point de départ du projet.

Le laboratoire d'entreprise Zero Trust est conçu comme une expérience d'ingénierie. La première étape construit une petite entreprise simulée : des comptes d'employés dans Active Directory, un portail métier, une base de données et un système de supervision. L'infrastructure combine GCP et un poste Windows local. Cet assemblage permet d'étudier deux chemins différents : les communications natives entre VM cloud et les communications du poste distant au travers de Tailscale.

L'état initial reproduit plusieurs mécanismes de confiance implicite. Les règles internes sont larges et les routes métier de l'application ne vérifient pas l'identité du visiteur. Des protections existent néanmoins, notamment l'administration contrôlée et certains mécanismes propres aux services. L'expérience ne suppose donc pas que toute tentative aboutira. Elle cherche à comprendre, pour chaque chemin, ce qui est accessible, quelle vérification est effectuée et quelle trace est produite.

La question centrale est la suivante : **comment des contrôles réseau, d'identité et de surveillance modifient-ils les possibilités d'accès et la visibilité des activités dans ce laboratoire ?** Pour y répondre, le projet organise la réalisation en quatre phases : infrastructure, configuration des services, tests offensifs puis contrôles et re-tests. La comparaison doit conserver des sources, cibles et méthodes cohérentes ; elle doit aussi distinguer un refus de sécurité d'un service indisponible ou d'un échec d'outil.

Les chapitres 1 à 4 présentent le cadrage, les fondements techniques, l'architecture et la réalisation des services. Les chapitres 5 et 6 traitent l'expérimentation et la validation comparative à partir des preuves collectées.

Chapitre 1

Contexte général et cadrage du projet

Introduction

Ce chapitre présente le cadre académique, le besoin auquel répond le laboratoire et les critères retenus pour évaluer le travail. Il précise également les limites de l'expérience et la façon dont les étapes de réalisation s'articulent.

1.1 Cadre académique et compétences mobilisées

Le projet est réalisé par Chouaib LAREDJ à l'École Nationale des Sciences Appliquées de Khouribga, Université Sultan Moulay Slimane, au sein du département Réseau, Télécommunication et Cybersécurité. Il s'inscrit dans la filière Ingénierie des Réseaux Intelligents et Cybersécurité, option Cybersécurité, sous l'encadrement de Dr JIHANE JEBRANE.

Le travail mobilise plusieurs dimensions de la formation : conception réseau, administration Windows et Linux, virtualisation, cloud, développement applicatif et analyse de sécurité. Leur articulation est essentielle. Une décision de routage influence l'accès aux services ; la configuration DNS conditionne le fonctionnement du domaine ; les règles de collecte déterminent ce que le SIEM pourra observer. Le laboratoire permet de relier ces connaissances à des symptômes et à des résultats concrets.

1.2 Présentation du projet

L'environnement simule une entreprise disposant d'un annuaire, de plusieurs catégories d'utilisateurs, d'un portail interne et d'informations métier synthétiques. Il comprend une infrastructure de surveillance et une source de tests offensifs dédiée. Le choix de services distincts permet d'étudier les relations entre identité, application et données, au lieu de réduire l'expérience à une seule machine vulnérable.

Le projet comprend une dimension de réalisation et une dimension d'évaluation. Construire les services fournit le support de l'expérience ; documenter les accès et leurs li-

mites permet d'analyser les effets des protections. Le résultat attendu est donc un ensemble cohérent de configurations, de tests, de preuves et d'explications.

1.3 Besoin métier et exigences du laboratoire

Le scénario retenu est celui d'une entreprise dont un collaborateur distant consulte un portail interne. Le système doit centraliser les comptes, conserver les données métier et permettre à l'administrateur de retrouver les traces d'une activité. Les catégories employés, managers, administrateurs et sous-traitants servent à construire des cas d'accès distincts ; leur présence dans l'annuaire ne prouve pas encore l'application de permissions dans le portail.

Les exigences fonctionnelles sont la gestion des identités, l'accès web aux données synthétiques et la consultation centralisée des événements. Les exigences de sécurité sont la limitation des flux au besoin, la séparation entre authentification et autorisation, et la traçabilité des essais. Enfin, les exigences expérimentales imposent un inventaire stable, des configurations conservées et des résultats datés. Les livrables associent donc infrastructure décrite, application, preuves et analyse critique, et non uniquement des captures de consoles.

1.4 Problématique et questions de recherche

La présence de plusieurs sous-réseaux et d'un VPN peut donner l'impression d'une architecture segmentée. Pourtant, si une règle permet tous les échanges entre les plages internes, la séparation logique ne limite guère les possibilités de communication. Au niveau applicatif, disposer d'un annuaire ne garantit pas davantage que chaque route web utilise l'identité de l'utilisateur.

Trois questions structurent l'étude :

1. Quels services sont joignables depuis une source donnée, et quels accès dépassent le besoin métier de cette source ?
2. À quel niveau l'identité et les droits sont-ils vérifiés : domaine Windows, application web ou base de données ?
3. Quelles activités sont effectivement enregistrées, transmises et interprétées par la chaîne de surveillance ?

L'évolution vers des contrôles Zero Trust sera évaluée à partir de ces questions. Une protection de l'application ne sera pas présentée comme une protection automatique de tous les protocoles du domaine.

1.5 Objectifs et critères de réussite

1.5.1 Construire une infrastructure explicable

Le premier objectif est de disposer d’une topologie dont chaque machine a un rôle identifié. Le provisionnement doit pouvoir être expliqué à partir du Terraform, puis rapproché de l’inventaire cloud. La cohérence attendue concerne le nombre d’instances, les réseaux, les accès d’administration et le placement des services.

1.5.2 Établir un état initial fonctionnel

Le deuxième objectif est de rendre possible un usage métier simple : un poste rejoint le domaine, un utilisateur ouvre le portail et l’application accède aux données. La surveillance doit recevoir des événements de cette activité normale. Cet état fonctionnel évite de confondre une panne initiale avec l’effet d’un contrôle déployé plus tard.

1.5.3 Identifier les frontières de confiance

Le troisième objectif est d’expliciter les décisions d’accès. La connectivité réseau, l’authentification et l’autorisation sont examinées séparément. Par exemple, une connexion TCP réussie vers PostgreSQL ne garantit ni une authentification réussie ni un droit de lecture sur une table.

1.5.4 Préparer une comparaison reproductible

Les tests seront définis par leur source, leur cible, le protocole, la route et la version de la configuration. Les contrôles seront comparés à l’état initial sur des chemins identiques lorsque cela est possible. Un changement de chemin fera l’objet d’une expérience distincte.

TABLE 1.1 – Objectifs et éléments permettant d’en juger la réalisation

Objectif	Élément de vérification
Infrastructure cohérente	Inventaire des VM et sous-réseaux, configuration Terraform et règles effectives.
Services opérationnels	Jonction au domaine, requête applicative, accès SQL autorisé et événements reçus.
Accès correctement caractérisés	Source, route et résultat documentés pour chaque test.
Surveillance exploitable	Événement local retrouvé dans Wazuh avec machine et horodatage.
Comparaison argumentée	Résultats avant/après accompagnés des configurations et limites de mesure.

1.6 Hypothèses et méthode d'évaluation

Trois hypothèses guident la comparaison. Premièrement, un filtrage ciblé devrait réduire les services accessibles depuis une source non autorisée, uniquement sur le chemin où ce filtrage s'applique. Deuxièmement, une intégration applicative de l'identité devrait distinguer absence de session, session autorisée et session sans permission suffisante. Troisièmement, une collecte correctement configurée devrait permettre de retrouver certaines actions dans le SIEM. Ces hypothèses sont à tester ; elles ne constituent pas des résultats acquis.

L'unité d'observation réseau est un couple cible-port testé depuis une source et une route identifiées. Un éventuel taux de joignabilité utilisera le même ensemble de couples avant et après, avec un dénominateur explicitement indiqué. Il ne mesurera ni toutes les vulnérabilités ni un pourcentage global de sécurité. Pour l'application, les essais devront comprendre un accès légitime et un accès refusé à une même ressource, afin de vérifier que le contrôle protège sans empêcher l'usage prévu.

Pour la surveillance, une preuve associera l'action réalisée, son horaire, la machine source et l'événement retrouvé avec son identifiant et sa règle éventuelle. L'absence de résultat sera examinée à chaque étape : production locale, transmission, indexation et recherche. Les versions, l'état des services et les changements de configuration seront consignés pour limiter les facteurs de confusion. Une panne, un outil incompatible ou une modification de route sera classé séparément d'un refus de sécurité.

1.7 Périmètre, contraintes et limites

Le périmètre technique comprend six VM GCP et un poste Windows local sous VMware. Les comptes et données représentent des profils fictifs. Le laboratoire ne reproduit pas la haute disponibilité, la diversité des terminaux ou la gouvernance d'une grande entreprise. Ces limites réduisent la portée des conclusions sans empêcher l'analyse des chemins étudiés.

La capacité matérielle locale a motivé la migration des serveurs vers le cloud. L'arrêt des instances entre les séances répond à une contrainte de budget ; il implique de contrôler leur disponibilité avant une capture ou un test. Un serveur arrêté constitue une absence de service, pas une preuve de filtrage. Les disques et snapshots doivent être suivis séparément de l'état d'alimentation des VM.

1.8 Organisation et chronologie de la réalisation

Les notes situent la préparation initiale VMware au début de juillet 2026. La configuration des principaux services se concentre ensuite entre le 24 et le 27 juillet : annuaire et poste Windows, application et base de données, puis supervision et ajustements de routage. La collecte d'une période normale de 24 heures est notée comme terminée le 30 juillet ; les événements historiques correspondants doivent être conservés pour l'attester.

La migration vers GCP constitue une évolution de la réalisation, à la jonction entre infrastructure et services. Les chapitres présentent ces travaux par fonction pour faciliter

la lecture, sans prétendre qu'ils ont été exécutés selon une séquence parfaitement linéaire. La phase offensive et la phase de validation sont présentées dans les chapitres 5 et 6 avec leurs résultats empiriques propres.

Conclusion

Le projet associe la construction d'un système d'information réduit à une méthode de vérification. Ses objectifs portent autant sur le fonctionnement des services que sur la capacité à expliquer un accès, un refus ou un événement observé.

Chapitre 2

État de l’art et fondements conceptuels

Introduction

L’étude s’appuie sur trois questions complémentaires : comment une ressource est-elle atteinte, comment un utilisateur est-il reconnu et comment son activité est-elle observée ? Les notions suivantes fournissent le vocabulaire nécessaire à l’analyse du laboratoire.

2.1 Confiance implicite et modèle périmétrique

Un modèle périmétrique organise la protection autour d’une frontière entre réseaux considérés comme internes et externes. Il reste possible d’y appliquer des contrôles internes fins. Le problème étudié ici apparaît lorsque l’entrée dans le réseau devient, en pratique, une condition suffisante pour atteindre des ressources ou utiliser des fonctions métier.

Dans le laboratoire, cette confiance implicite se traduit par des règles réseau étendues et des routes applicatives sans contrôle d’identité. La notion de réseau « plat » décrit alors une faible séparation des communications autorisées, même si plusieurs sous-réseaux IP existent. Le terme *Legacy* désigne cet état expérimental initial ; il ne signifie pas que tous les composants sont obsolètes ou dépourvus de toute protection.

2.2 Principes fondamentaux du Zero Trust et NIST SP 800-207

Le paradigme Zero Trust rompt radicalement avec le modèle traditionnel de sécurité périmétrique fondé sur la confiance implicite accordée aux flux internes. Formalisé par le National Institute of Standards and Technology dans le standard NIST SP 800-207 [1], le modèle Zero Trust repose sur le principe axiomatique « *Never Trust, Always Verify* » (ne jamais faire confiance, toujours vérifier). Il postule que des acteurs hostiles opèrent déjà

au sein de l’infrastructure (*Assume Breach* [17]) et interdit toute déduction de confiance à partir de la seule localisation topologique d’une entité [19].

2.2.1 Les sept principes cardinaux (Core Tenets) du NIST SP 800-207

Le NIST SP 800-207 présente sept principes directeurs. Ils définissent une cible architecturale ; le laboratoire n’en démontre qu’une mise en œuvre partielle, précisée après leur présentation :

1. **Considération universelle des ressources** : Toutes les sources de données et charges de travail sont traitées individuellement comme des ressources protégées.
2. **Sécurisation systématique des communications** : Les communications doivent protéger la confidentialité, l’intégrité et l’authenticité de leur source indépendamment de leur emplacement réseau.
3. **Accès accordé par session individuelle** : Les droits sont octroyés avec le moindre privilège (*Least Privilege* [19, 24]) pour une session d’accès à la ressource considérée ; une autorisation sur une ressource ne vaut pas autorisation générale.
4. **Détermination dynamique de la politique d’accès** : La politique d’accès tient compte de l’identité, de l’état de l’actif et, selon le besoin, d’attributs contextuels ; l’ABAC fournit un cadre complémentaire [18].
5. **Surveillance continue de la posture des actifs** : L’entreprise surveille et mesure l’intégrité et la posture de sécurité des actifs possédés ou associés.
6. **Authentification et autorisation dynamiques avant tout accès** : L’évaluation des identités et des permissions est strictement antérieure à l’établissement de la communication, avec réévaluation possible pendant la session selon la politique et le risque.
7. **Collecte télémétrique et amélioration itérative** : L’entreprise collecte des informations sur les actifs, les communications et les accès pour améliorer sa politique de sécurité.

Portée de l’implémentation. Les essais établissent des contrôles d’identité, de rôle, de réseau, de privilèges SQL et de télémétrie sélectionnés. Ils ne démontrent pas le chiffrement de tous les transports : HTTP demeure présent pour le portail/OIDC et l’assurance TLS du transport PostgreSQL n’est pas établie. La posture du terminal n’alimente pas une décision d’accès dynamique démontrée. Les autorisations reposent sur des rôles, adresses et règles configurées ; aucune conformité globale au NIST ni certification de maturité CISA n’est revendiquée. Le modèle CISA distingue cinq piliers et trois capacités transversales ; visibilité et automatisation sont des capacités transversales, pas des piliers supplémentaires.

2.2.2 Architecture logique : Découplage Plan de Contrôle et Plan de Données

Le modèle logique NIST SP 800-207 articule la gouvernance des flux autour d’un découplage strict entre le plan de contrôle (*Control Plane*) et le plan de données (*Data Plane*) :

- **Point de décision de politique (PDP – *Policy Decision Point*)** : Entité logique centrale responsable de l’évaluation et de la promulgation des autorisations. Le standard la subdivise en :
 - **Moteur de politique (PE – *Policy Engine*)** : Algorithme décisionnel tranchant l’octroi, le refus ou la révocation de l’accès à une ressource à partir des politiques organisationnelles et des flux de renseignements sur les menaces.
 - **Administrateur de politique (PA – *Policy Administrator*)** : Composant exécutif chargé de commander le chemin de communication, générant les jetons d’accès ou commandant dynamiquement les passerelles de filtrage.
- **Point d’application de la politique (PEP – *Policy Enforcement Point*)** : Passerelle opérant sur le plan de données, chargée d’intercepter, inspecter, autoriser ou rompre physiquement les connexions entre un sujet et une ressource.

Dans le laboratoire, Keycloak fournit l’identité et les jetons OIDC ; le décorateur Flask décide de l’autorisation applicative et applique le refus selon le rôle. Les règles ingress GCP et les permissions PostgreSQL imposent des contrôles distincts sur le réseau et les données. Cette correspondance est fonctionnelle et partielle : aucun moteur central ne réévalue dynamiquement toutes les décisions à partir de la posture des terminaux. Wazuh collecte et corrèle des événements ; sa réponse active commande le pare-feu local de l’agent, sans intégration démontrée à un PA Keycloak ni révocation démontrée d’une session OIDC.

2.3 Identité, authentification et autorisation

2.3.1 Annuaire Active Directory

AD DS organise des objets tels que comptes, ordinateurs et groupes dans un annuaire. Il fournit des mécanismes d’authentification et de contrôle d’accès aux objets [2]. Dans le laboratoire, il centralise les identités de `corp.local`. Les OU servent à organiser les objets ; les groupes expriment des ensembles d’appartenance auxquels des droits peuvent être associés. Un groupe nommé « Admins » ne suffit pas à prouver que des privilèges particuliers ont été accordés.

2.3.2 LDAP, Kerberos et dépendances du domaine

LDAP permet de consulter l’annuaire et constitue le mécanisme de fédération prévu entre Keycloak et AD. Kerberos intervient dans l’authentification Windows par un système de tickets. Son fonctionnement dépend notamment de la résolution des services du domaine

et de la cohérence temporelle. Ces dépendances expliquent l’importance du DNS et des vérifications de connectivité lors de la jonction du poste local.

2.3.3 Authentification applicative avec OIDC

OIDC ajoute une couche d’identité au cadre OAuth 2.0 et permet à une application cliente de vérifier une authentification à partir des informations fournies par un serveur d’identité [3]. Dans le projet, Keycloak est destiné à ce rôle. Une fédération LDAP configurée ne signifie cependant pas que Flask lui délègue déjà les connexions : l’application doit être intégrée au parcours d’authentification.

Dans un parcours OIDC avec code d’autorisation, le navigateur est redirigé vers le fournisseur d’identité, puis revient à l’application avec un code. Le client échange ce code contre des jetons et vérifie les informations d’identité avant d’établir sa session. Les contrôles portent notamment sur la signature, l’émetteur, le destinataire et la validité temporelle du jeton ; la corrélation du parcours doit également être protégée [3]. Le jeton d’identité ne remplace pas une vérification des droits sur chaque fonction métier. Les captures LDAP seules ne démontrent pas ce parcours ; les essais OIDC, OTP et RBAC sont détaillés au chapitre de validation.

2.3.4 MFA et contrôle des rôles

La MFA ajoute un facteur à l’authentification ; le RBAC associe les permissions aux rôles. Une personne correctement authentifiée peut rester non autorisée à ouvrir une page d’administration. Le guide Keycloak documente notamment les fournisseurs LDAP, les rôles et les parcours d’authentification [4]. Ces fonctions sont évaluées sur les parcours applicatifs détaillés au chapitre de validation. Elles ne s’étendent pas automatiquement aux connexions SMB ou RDP.

2.4 Segmentation et connectivité

2.4.1 Sous-réseaux et filtrage

Les sous-réseaux organisent l’adressage. Les règles de pare-feu déterminent les communications autorisées selon leurs critères. Sur GCP, les règles VPC concernent le trafic des instances et tiennent notamment compte des sources, cibles et protocoles [5]. Il faut donc examiner les règles effectives, et pas uniquement le diagramme réseau.

2.4.2 Réseau overlay et routeur de sous-réseau

Un routeur Tailscale annonce des réseaux accessibles à travers lui et permet de joindre des machines qui ne sont pas elles-mêmes membres du tailnet. Les routes et les politiques d’accès constituent deux aspects distincts de cette connectivité [6]. Dans le laboratoire, ce

dispositif relie le poste VMware aux plages GCP. Une communication native entre deux VM GCP n’emprunte pas nécessairement cet overlay.

2.4.3 Administration par IAP

IAP TCP forwarding fournit un chemin d’administration vers une instance à travers un tunnel, sous réserve des droits IAM et des règles réseau nécessaires [7]. Il permet ici de distinguer l’accès d’administration SSH/RDP des échanges métier. Protéger ce chemin ne suffit pas à sécuriser toutes les communications internes.

2.5 Télémétrie, SIEM et détection

Sysmon est un service et un pilote Windows qui produisent des événements détaillés, notamment sur les processus et, selon la configuration, les connexions réseau. Il ne réalise pas à lui seul l’analyse de ces événements [8]. Les règles de collecte choisies déterminent donc ce qui devient observable.

Wazuh associe des agents à des composants centraux de collecte, d’analyse, d’indexation et de visualisation [9]. Dans le laboratoire, les rôles centraux sont regroupés sur une machine. Une distinction est nécessaire entre agent connecté, événement reçu, alerte produite et réponse exécutée. Chacun de ces états demande une preuve différente.

La chaîne d’analyse distingue le producteur local, l’agent de collecte, le serveur Wazuh qui décode et applique les règles, l’indexeur qui conserve les résultats et le tableau de bord qui les présente [9]. Une recherche vide peut donc résulter d’un filtre incorrect ou d’une rupture de collecte, et pas uniquement d’une absence d’activité. Dans les preuves reçues, une connexion Windows réussie est retrouvée avec son identifiant d’événement et sa règle ; cela établit un chemin de collecte pour cette machine, pas la couverture de toutes les techniques adverses.

2.6 Données et contrôle d’accès PostgreSQL

Une connexion à PostgreSQL dépend de plusieurs conditions : service en écoute, route disponible, filtrage réseau, sélection d’une règle d’authentification et permissions SQL. Le fichier `pg_hba.conf` utilise des critères tels que l’adresse cliente, la base et le rôle, avec une sélection ordonnée des règles [10]. Le rejet d’une connexion à ce niveau ne peut pas être attribué automatiquement à un pare-feu réseau.

2.7 Simulation d’attaques et MITRE ATT&CK

MITRE ATT&CK organise des connaissances sur les tactiques et techniques adverses à partir d’observations [11]. Il fournit un cadre de description des tests, sans constituer

une liste d'attaques à exécuter intégralement. Le laboratoire sélectionne des scénarios en fonction des services réellement présents.

La reconnaissance établit ce qui est joignable ; les tests d'accès évaluent les vérifications d'identité ou de permission ; l'examen des événements mesure la visibilité. Les tentatives non exécutées ou interrompues par une incompatibilité d'outil seront distinguées des refus effectivement produits par un contrôle.

2.8 Approches comparables et positionnement

Quatre approches complémentaires sont comparées : contrôler l'administration, centraliser l'identité, filtrer les communications et observer les activités. Leur articulation est plus informative qu'un simple classement des outils.

TABLE 2.1 – Comparaison des approches dans le périmètre du projet

Approche	Apport	Limite à examiner
Tunnel d'administration	Accès contrôlé aux interfaces SSH/RDP.	Ne définit pas les droits sur le portail métier.
Annuaire centralisé	Cohérence des comptes et des groupes.	Une application non intégrée peut ignorer l'identité du domaine.
Filtrage par besoin	Réduction des communications autorisées.	La portée dépend du chemin réseau réellement traversé.
Surveillance centralisée	Mise en relation des traces des machines.	L'absence d'alerte ne suffit pas à conclure à l'absence d'activité.

Une approche centrée sur l'identité distingue les utilisateurs, mais ne ferme pas à elle seule un port SQL accessible. Une approche centrée sur la segmentation réduit les chemins possibles, mais ne distingue pas deux rôles utilisant la même page web. La surveillance apporte une capacité d'analyse, sans se substituer à ces restrictions. Le choix retenu combine donc les trois dimensions, conformément à la distinction entre ressource, identité et décision d'accès proposée par le NIST [1].

Cette revue ciblée s'appuie sur une référence d'architecture et sur les spécifications ou documentations des mécanismes employés. Elle justifie les choix du laboratoire ; elle n'est ni une revue systématique de toutes les publications Zero Trust ni un classement expérimental des produits. La contribution du projet est une mise en œuvre hybride accompagnée d'une comparaison sur des chemins explicités. Les performances et les résultats d'autres travaux ne sont pas présentés comme des mesures réalisées ici.

Conclusion

La sécurité du système résulte d'une combinaison de contrôles dont les portées diffèrent. L'analyse du laboratoire doit conserver cette distinction pour expliquer ce qu'un test

démontre réellement.

Chapitre 3

Conception et architecture du laboratoire

Introduction

L'architecture représente une entreprise de petite taille, avec un poste utilisateur distant, des services métier et une supervision. Ce chapitre décrit le rôle de chaque machine, les choix de placement et le déroulement des échanges dans l'état initial.

3.1 Besoins et choix de conception

Le laboratoire doit permettre d'administrer les serveurs, de gérer des identités, de consulter des données métier et d'observer les activités. La séparation des fonctions entre VM rend les dépendances visibles : la base de données peut fonctionner alors que le portail est arrêté, et l'annuaire peut être opérationnel sans que l'application exploite ses identités.

La première architecture locale a été adaptée aux ressources disponibles en transférant les serveurs sur GCP. Le poste Windows reste sous VMware pour conserver un scénario d'accès distant. Terraform décrit les ressources cloud ; Tailscale fournit la continuité de réseau nécessaire au poste local. Cette combinaison maintient un environnement réaliste tout en limitant le nombre de systèmes à administrer.

3.2 Inventaire et rôle de chaque machine

TABLE 3.1 – Placement et systèmes déclarés dans les sources du laboratoire

Machine	Système prévu	Placement
vm-ad	Windows Server 2022	GCP, sous-réseau serveurs.
vm-web	Ubuntu 22.04	GCP, sous-réseau serveurs.
vm-db	Ubuntu 22.04	GCP, sous-réseau serveurs.
vm-keycloak	Ubuntu 22.04	GCP, sous-réseau serveurs.
vm-wazuh	Ubuntu 22.04	GCP, sous-réseau gestion.
vm-attacker	Debian GNU/Linux 11 (Bullseye)	GCP, 192.168.1.2; Nmap et Hydra présents, Impacket absent au contrôle SSH du 05/10/2026.
vm-sysmon	Windows 10 Pro	Poste local sous VMware Workstation.

Le contrôle SSH du 5 octobre 2026 confirme que le système invité de vm-attacker est Debian GNU/Linux 11 (Bullseye), noyau 5.10.0-46-cloud-amd64, adresse privée 192.168.1.2. Les paquets relevés sont Nmap 7.91+dfsg1+really7.80+dfsg1-2 et Hydra 9.1-1. Les commandes `impacket-GetUserSPNs` et `GetUserSPNs.py` sont absentes et le paquet `impacket-scripts` n'a pas été trouvé. Cette VM GCP est donc un hôte Debian équipé de quelques outils de test, pas un système Kali. Les mentions de Kali dans l'historique concernent la machine préparée sous VMware ; les deux environnements doivent rester distingués dans les résultats.

Le tableau 3.2 détaille la correspondance architecturale entre chaque actif du laboratoire, son rôle logique selon le standard NIST SP 800-207 et son rattachement aux piliers du modèle de maturité CISA ZTMM.

TABLE 3.2 – Correspondance architecturale entre les actifs du laboratoire, le NIST SP 800-207 et le modèle de maturité CISA

Actif du lab	Rôle logique NIST SP 800-207	Rattachement CISA ZTMM [16]	Mécanisme technique de contrôle
vm-ad	Référentiel d'identité / Control Plane	Identité	Catalogue Active Directory DS, Kerberos KDC, annuaire LDAPS TLS 1.3 (RFC 8446 [20]).
vm-keycloak	Service d'identité; appui à la décision d'accès	Identité / Applications	Fédération LDAP, défi OTP RFC 6238 [22], émission de jetons OIDC JWT RFC 7519 [21].
vm-web	Application PEP (L7) & Routeur d'enclave	Applications / Réseau	Décorateur RBAC Flask (<code>portal_roles</code>), tunnel WireGuard Tailscale [25], pare-feu iptables.
vm-db	Resource Layer & Data PEP	Données	Moteur PostgreSQL, authentification <code>pg_hba.conf</code> , séparation de privilèges SQL (<code>REVOKE/GRANT</code>).
vm-wazuh	Composant CDM / SIEM centralisé	Visibilité & Analytique / Automatisation	Collecteur d'événements OSSEC/Wazuh, corrélation Règle 100510, moteur d'isolement Active Response (<code>ar-drop-ip</code>).
vm-sysmon	Sujet distant & Hôte instrumenté	Dispositifs / Identité	Télémétrie noyau Sysmon [8], agent Tailscale, authentification Kerberos/domaine.
vm-attacker	Sujet hostile non authentifié	Hors piliers : source de test	Source offensive pour cartographie Nmap et pivot latéral intra-VPC.

3.2.1 vm-ad : référentiel d'identité

vm-ad héberge le contrôleur du domaine `corp.local`. Il fournit les comptes utilisés pour représenter employés, managers, administrateurs et sous-traitants. Le poste Windows utilise les services du domaine pour la jonction et l'authentification. Keycloak consulte l'annuaire pour la fédération d'identités. Une indisponibilité de cette VM affecte donc plusieurs fonctions, même si les services web et SQL demeurent opérationnels.

À l'adresse interne 10.0.20.5, cette machine fournit le référentiel des comptes et groupes ainsi que les services DNS du domaine. Le poste doit résoudre correctement les noms du domaine avant de pouvoir utiliser son authentification. LDAP permet à Keycloak de rechercher les identités; Kerberos participe aux connexions Windows. Ces usages ne sont pas interchangeables : réussir une consultation LDAP ne démontre pas une connexion applicative autorisée.

Cette VM est également une source de journaux de sécurité transmise à Wazuh.

L'événement 4624 collecté en octobre atteste une connexion Windows réussie sur cette source ; il n'établit pas une attaque. Pour le diagnostic, on sépare donc résolution DNS, disponibilité de l'annuaire, validité du compte et visibilité de son activité.

3.2.2 vm-sysmon : poste de travail observé

Le poste local représente le terminal d'un employé. Il combine navigateur, appartenance au domaine, client Tailscale, Sysmon et agent Wazuh. Son rôle est double : effectuer les actions utilisateur et produire une télémétrie permettant de les examiner. Il constitue une source distincte de vm-attacker, car son trafic traverse la liaison hybride.

Le navigateur consomme le portail de vm-web, tandis que les fonctions du domaine dépendent de vm-ad. Le client Tailscale donne un chemin vers les sous-réseaux annoncés par vm-web ; il ne remplace ni l'identité Windows ni les permissions applicatives. Sysmon enrichit les événements locaux selon sa configuration, et l'agent Wazuh transmet les canaux sélectionnés au serveur de surveillance.

Ce placement permet de suivre une action depuis le poste jusqu'aux services cloud. Il impose cependant de vérifier le poste, le tunnel et le routeur avant d'interpréter un échec d'accès. L'adresse Tailscale capturée est `adresse tailnet masquée`. Les captures de détails indiquent une dernière présence à 12 :46 UTC, sans date explicite sur cette vue ; elles ne prouvent pas une connexion permanente.

3.2.3 vm-web : application et passerelle hybride

vm-web sert le portail Flask et effectue les requêtes SQL vers vm-db. Il joue également le rôle de routeur de sous-réseau Tailscale. Cette mutualisation simplifie le laboratoire mais crée une dépendance : arrêter vm-web peut interrompre à la fois le portail et l'accès du poste local aux autres services. Les deux fonctions doivent être distinguées lors d'un diagnostic.

Son adresse interne est `10.0.20.2` et son adresse Tailscale capturée `adresse tailnet masquée`. Les routes approuvées concernent `10.0.20.0/24` et `10.0.99.0/24`. Le rôle de passerelle consiste à acheminer des communications vers ces réseaux ; celui de serveur web consiste à traiter une requête HTTP, exécuter la logique Flask et demander les données à PostgreSQL. Une route approuvée ne constitue pas une preuve de bon acheminement au moment du test.

La configuration Flask capturée prévoit une écoute sur le port 80, alors que le test ponctuel documenté utilise le port local 5000. Le résultat actuel de `/employee` est une redirection vers `/login`, à distinguer du code historique sans contrôle d'identité. Cette VM constitue aussi un point de passage sensible : les droits SQL de l'application doivent rester limités même si le serveur web est compromis. Sa dernière présence Tailscale affichée est le 5 octobre à 14 :33 UTC.

3.2.4 vm-db : dépôt des données métier

vm-db conserve les tables applicatives, notamment les employés et clients fictifs. Le portail se connecte avec un rôle SQL dédié. La base applique ses propres mécanismes d'authentification et de permission. Un utilisateur qui lit des données à travers Flask n'ouvre pas nécessairement une session SQL directe : les droits utilisés sont alors ceux de l'application.

À 10.0.20.4, PostgreSQL constitue la couche de persistance de l'application. Les preuves identifient la base `corp_data`, les tables `employees` et `clients`, ainsi que le rôle `app_user`. Le service est configuré sur le port 5432 ; l'écoute, les règles de `pg_hba.conf` et les permissions sur tables et séquences sont des contrôles distincts.

Dans le parcours normal, vm-web est le consommateur des données, pas le navigateur du collaborateur. Pour l'expérience, un essai SQL direct depuis vm-attacker doit être distingué d'un accès passant par vm-web : l'adresse cliente vue par la base et les droits mobilisés diffèrent. Cette séparation permet d'expliquer pourquoi un refus direct ne garantit pas l'impossibilité d'accéder aux données par une application autorisée.

3.2.5 vm-keycloak : identité applicative

vm-keycloak prépare une couche d'identité destinée aux applications. Sa fédération LDAP permet de relier les comptes du domaine à son realm. Dans l'état initial étudié, son existence n'impose pas une authentification aux routes Flask. L'intégration applicative constitue une étape distincte détaillée avec les contrôles de phase 4.

Cette machine, située à 10.0.20.3, héberge le realm `corp` et le fournisseur LDAP `corp-ad`. Elle consulte vm-ad pour les identités ; dans le parcours cible, elle authentifie l'utilisateur dans l'intégration OIDC évaluée ensuite et fournira les jetons nécessaires au client Flask. Elle n'est donc ni le serveur des données métier ni un remplacement du contrôleur de domaine.

Les captures récentes prouvent la configuration LDAP et la réussite du test de connexion. La réussite du test d'authentification du compte de liaison est rapportée par l'utilisateur, sans capture distincte. Aucun de ces contrôles ne démontre à lui seul la synchronisation complète, une connexion utilisateur OIDC ou l'application du RBAC. Le mode de développement et la liaison LDAP sans StartTLS observés appartiennent au laboratoire et ne sont pas présentés comme une configuration de production durcie.

3.2.6 vm-wazuh : point d'observation

vm-wazuh regroupe les composants centraux de surveillance. Les cinq agents décrits dans les notes se trouvent sur vm-ad, vm-web, vm-db, vm-keycloak et vm-sysmon. La VM attaquante n'est pas comptée parmi ces cinq agents. Wazuh permet de rechercher des événements par machine et par période ; il ne garantit pas une visibilité exhaustive de tous les paquets réseau.

Placée dans le sous-réseau de gestion à 10.0.99.2, cette machine réunit le gestionnaire, l'indexeur et le tableau de bord. Le gestionnaire reçoit et analyse les événements ; l'indexeur rend les résultats recherchables ; le tableau de bord permet leur consultation. Les flux agents et l'accès à l'interface ont des fonctions différentes : atteindre l'interface HTTPS ne prouve pas que chaque agent transmet ses journaux.

Au moment de la collecte, seul vm-ad est affiché actif ; les quatre autres agents sont déconnectés. L'exemple Security 4624 associé à la règle 60106 fournit une preuve de collecte et de classement pour AD. La métadonnée MITRE T1078 attachée à cette règle ne transforme pas une connexion normale en attaque confirmée. Les essais dédiés du chapitre de validation établissent ensuite des alertes applicatives et un déclenchement synthétique de réponse active.

3.2.7 vm-attacker : source expérimentale

vm-attacker est la source GCP des tests contrôlés et se trouve dans le sous-réseau attaquant. Dans les scénarios natifs, son trafic vers les serveurs passe par le VPC GCP, et non automatiquement par Tailscale. L'image déclarée est Debian 11 ; l'inventaire réel du système et des outils doit être joint aux résultats. La machine Kali décrite dans l'historique VMware est une source distincte tant qu'une preuve ne confirme pas le contraire.

Son adresse 192.168.1.2 identifie la source de l'expérience, et non un poste utilisateur légitime. Nmap sert à caractériser les services joignables ; les autres outils sont utilisés seulement dans des scénarios autorisés et documentés. Le contrôle du 5 octobre confirme Nmap et Hydra présents, et Impacket absent : un scénario dépendant d'Impacket ne peut donc pas être déclaré exécuté.

Conserver cette source pour les re-tests limite les variations dues au changement de machine ou de route. Ses résultats doivent préciser cible, port, commande, version et horaire. L'absence d'agent Wazuh sur vm-attacker signifie aussi que la visibilité repose principalement sur les événements des cibles surveillées ; elle ne garantit pas un journal centralisé de toutes les actions lancées par l'outil offensif.

3.3 Topologie et frontières du laboratoire

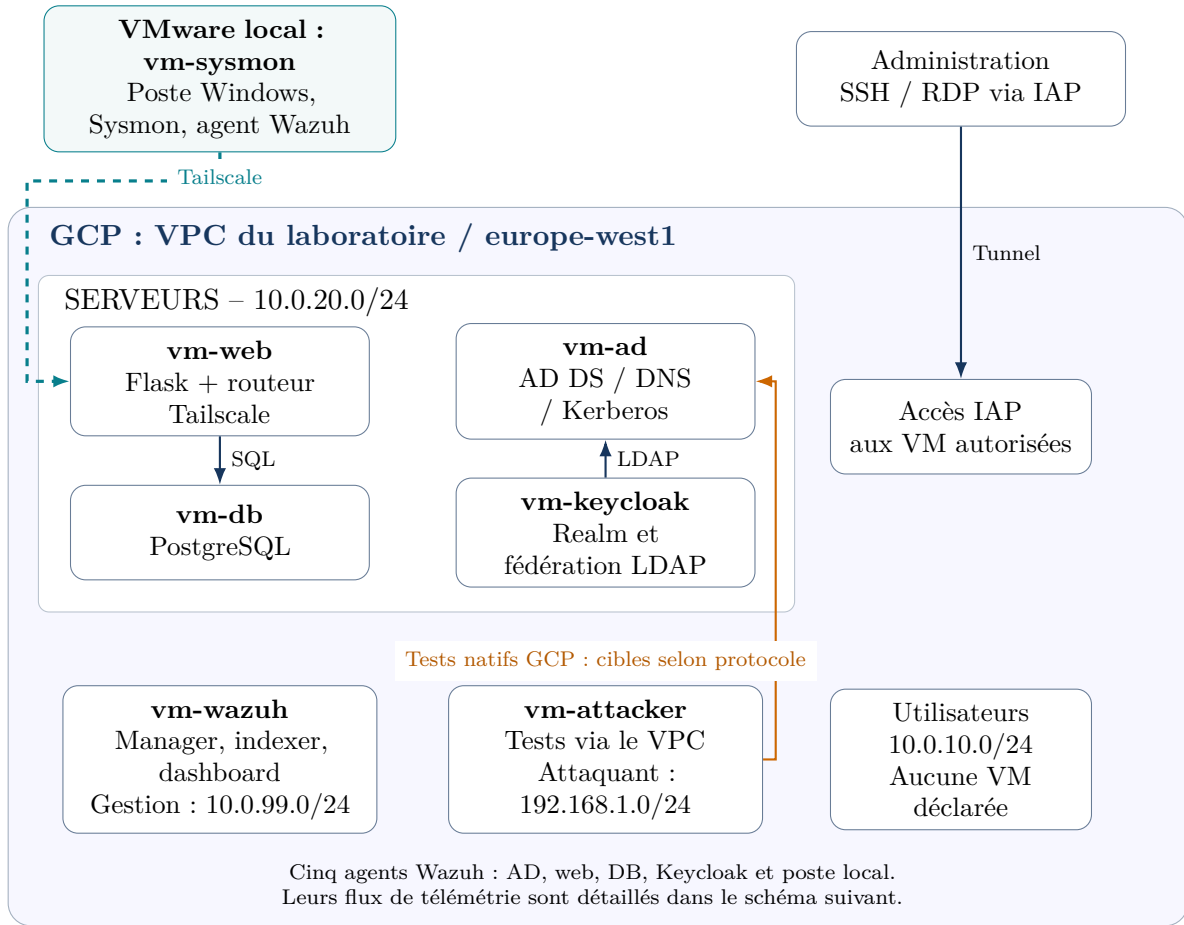


FIGURE 3.1 – Topologie logique de l'état initial. Le trait discontinu représente la liaison Tailscale ; le trait orange illustre le chemin des tests natifs GCP, sans affirmer leur réussite. Les flèches de service montrent des dépendances choisies et non une politique exhaustive.

Le sous-réseau utilisateurs est défini dans le Terraform mais ne contient pas la VM Windows locale. Celle-ci demeure hors du VPC et rejoint les services par le routeur. Le plan d'adressage ne permet pas d'assimiler la route Tailscale 10.0.0.0/8, mentionnée dans les notes, à l'ensemble du laboratoire : elle couvre les trois plages en 10.0.x.x, mais pas 192.168.1.0/24.

3.4 Fonctionnement de l'architecture traditionnelle

3.4.1 Parcours du poste vers le domaine

Le poste Windows établit sa liaison Tailscale et dispose d'une route vers les réseaux annoncés. Les requêtes destinées aux adresses internes passent par vm-web, qui les transmet dans GCP. Pour localiser les services AD, le poste utilise le DNS du domaine. Les échanges

de jonction et d'authentification rejoignent ensuite vm-ad. Le retour des paquets dépend du routage et de la traduction d'adresse appliquée au passage du routeur.

3.4.2 Parcours d'une consultation métier

L'utilisateur ouvre le portail dans son navigateur. Dans le code initial examiné, la route appelée exécute son traitement sans demander de connexion applicative. Pour une page de données, Flask se connecte à PostgreSQL avec les paramètres du rôle applicatif, exécute une requête puis produit une page HTML. La réussite de cette consultation ne prouve pas que le visiteur dispose lui-même de droits SQL.

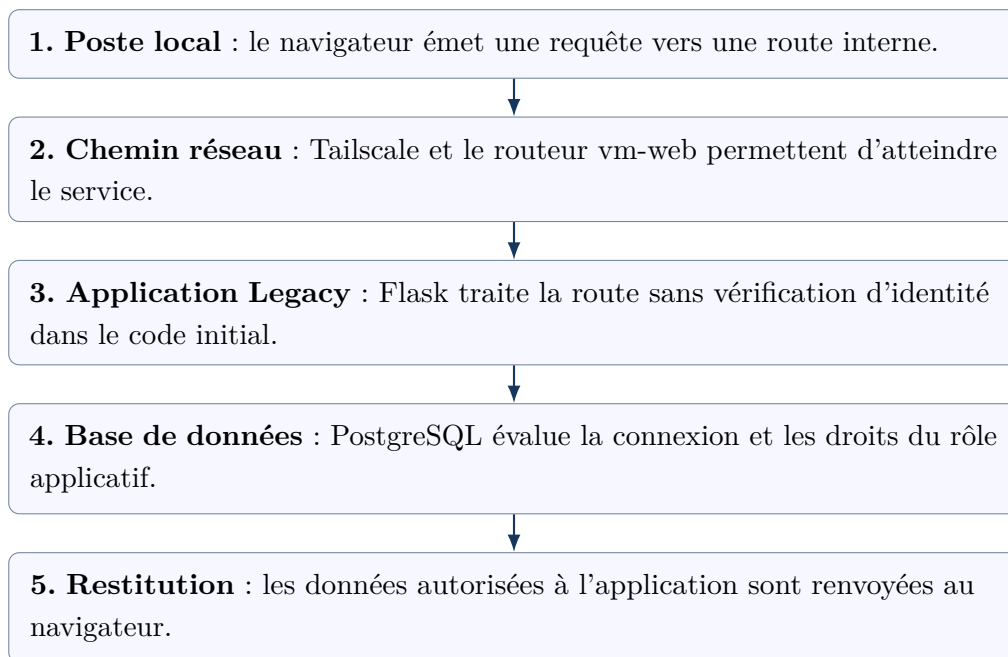


FIGURE 3.2 – Parcours métier initial : la connexion au réseau, la session Windows et les droits SQL sont des mécanismes distincts. L'étape d'autorisation applicative manque dans le code Legacy.

3.4.3 Place de Keycloak dans cet état

Keycloak peut consulter AD sans intervenir dans le parcours précédent. Un compte visible dans son realm n'établit donc pas que le portail exige une authentification. Pour transformer le parcours, Flask devra déléguer la connexion à Keycloak puis vérifier les permissions nécessaires à la route. Cette transformation appartient à la phase défensive.

3.4.4 Chaîne d'observation

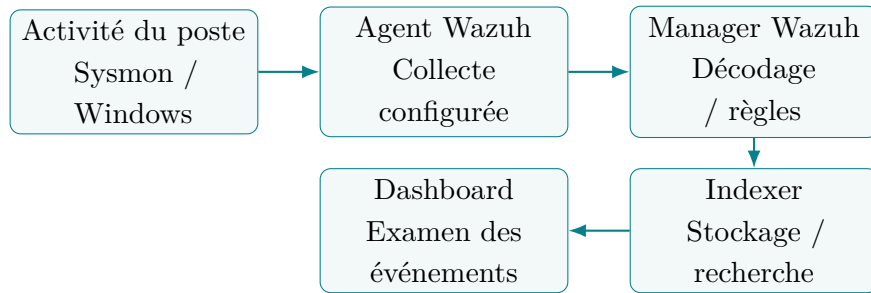


FIGURE 3.3 – Chaîne d'observation simplifiée. Les serveurs Linux et AD possèdent aussi leurs agents et leurs sources de journaux ; la capture d'un événement local doit être reliée à sa réception centrale.

3.5 Pourquoi cet état reste fondé sur la confiance implicite

Le Terraform examiné autorise TCP, UDP et ICMP depuis les quatre plages internes sans restriction de ports dans la règle générale. Cette règle accorde une connectivité étendue aux machines internes, y compris à la source de tests. L'absence d'authentification des routes Flask transforme ensuite une partie de cette connectivité en accès métier. Ces deux propriétés concernent des couches différentes et peuvent se renforcer.

Des limites subsistent : les services doivent être démarrés, les routes doivent fonctionner et PostgreSQL peut rejeter une connexion. La présence d'AD, de Wazuh et d'un tunnel chiffré ne supprime pas les faiblesses décrites ; elle fournit des fonctions d'identité, d'observation et de transport qui devront être articulées avec des décisions d'accès plus fines.

3.6 Protocole de vérification de l'architecture

Le protocole conserve pour chaque observation la date, la machine source, le chemin réseau, la cible et le résultat. Il distingue le code prévu, la configuration appliquée et la preuve de fonctionnement. Les artefacts probatoires présentés dans le chapitre suivant établissent empiriquement la placement documenté des services, de la connectivité réseau et des dépendances d'authentification exposées dans ce protocole.

Conclusion

L'architecture hybride met en relation trois chaînes : l'accès utilisateur, les services métier et la surveillance. L'explication de ces chaînes permet de comprendre pourquoi un tunnel ou un annuaire fonctionnel ne suffisent pas à garantir l'autorisation de chaque accès.

Chapitre 4

Réalisation des phases 1 et 2 : infrastructure et services

Introduction

Les phases initiales construisent l’environnement servant de référence aux tests. Ce chapitre décrit les choix réellement présents dans les sources, les étapes rapportées par les notes et les contrôles de fonctionnement documentés par les captures conservées.

4.1 Phase 1 : mise en place de l’infrastructure

4.1.1 Préparation sous VMware et migration

La première installation sous VMware permet d’attribuer un rôle aux systèmes, de configurer les réseaux et de préparer les systèmes d’exploitation. Le déplacement des serveurs vers GCP répond ensuite aux limites de capacité locale. Le poste `vm-sysmon` est conservé sur VMware : il devient le terminal distant d’une architecture hybride et non une septième instance cloud.

Cette évolution impose de remplacer des communications locales directes par une liaison routée. Les adresses initiales VMware ne doivent pas être utilisées comme preuve des adresses GCP. Les relevés de configuration en environnement GCP attestent que l’application Flask déployée exploite exclusivement les interfaces d’infrastructure cloud (`10.0.20.4` pour l’accès PostgreSQL et `10.0.20.3` pour la fédération Keycloak).

4.1.2 Infrastructure as Code et ressources déclarées

Terraform décrit les ressources à gérer et les changements nécessaires pour atteindre l’état déclaré [12]. Dans le projet, `network.tf` définit le VPC, les sous-réseaux, le routeur cloud et le NAT ; `compute.tf` définit les instances ; `firewall.tf` décrit les règles d’accès. Cette séparation facilite l’explication de la topologie et l’examen des évolutions.

Les déclarations indiquent deux VM de type e2-micro pour web et base de données, des e2-medium pour AD, Keycloak et attaquant, ainsi qu'une e2-standard-2 pour Wazuh. Ce sont les tailles du source examiné, à rapprocher de l'inventaire réel. Les paramètres `desired_status` y sont positionnés sur `TERMINATED`, état arrêté destiné à la gestion des séances.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.1 – Inventaire des instances du laboratoire

4.1.3 Organisation du VPC et sortie réseau

Le VPC est déclaré sans création automatique de sous-réseaux. Les quatre plages sont définies explicitement, ce qui rend leur usage lisible. Les interfaces des VM du source ne contiennent pas de bloc attribuant une adresse externe. Un Cloud Router et une configuration Cloud NAT sont prévus pour les communications sortantes nécessaires, par exemple pour les mises à jour. Leur présence effective et leur portée seront vérifiées dans la console.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.2 – Plan d'adressage GCP

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.3 – Configuration de la sortie réseau

4.1.4 Pare-feu initial et accès IAP

La règle `allow-iap-ssh-rdp` autorise TCP 22 et 3389 depuis 35.235.240.0/20, en ciblant les instances portant le tag `allow-iap`. La règle `allow-internal-vpc` autorise TCP, UDP et ICMP depuis les quatre plages du laboratoire. Aucun port n'est spécifié dans ses blocs TCP/UDP : cette règle constitue un élément central du périmètre initial permissif.

Les fichiers de configuration indiquent une intention ; la capture doit montrer les règles appliquées, leurs priorités et leurs cibles. Les pare-feu des systèmes et les politiques des services restent des couches distinctes. Une connexion refusée par PostgreSQL peut donc coexister avec une règle VPC permissive.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.4 – Règles réseau initiales

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.5 – Sortie horodatée de l'hôte vm-web dans la session distante

4.1.5 Snapshots et points de restauration

Les snapshots doivent permettre de retrouver un état de disque identifié. Une liste de noms seule ne prouve ni la couverture de toutes les machines ni la date de l'état préservé. Le rapport associera chaque snapshot à son disque source et à son horodatage. Le poste local exige une preuve VMware distincte si un point de restauration y est conservé.

Le contenu du disque et l'état réseau du projet ne sont pas interchangeables : une restauration de disque ne rétablit pas nécessairement toutes les règles VPC. La documentation doit donc conserver les configurations utiles en complément des points de restauration. La console GCP consultée le 5 octobre 2026 présente 19 snapshots manuels dans la localisation eu. Les valeurs ci-dessous ont été transcrites depuis la vue *Compute Engine – Snapshots*. La valeur graphique de la colonne d'état n'étant pas incluse dans la transcription, le tableau ne la déduit pas ; elle devra être confirmée séparément si le rapport doit affirmer que tous les snapshots sont à l'état *Ready*.

TABLE 4.1: Inventaire des snapshots GCP observés le 5 octobre 2026

Snapshot	Disque source	Création (UTC+1)	Taille	Disque
kpyqaiac1lfs	vm-wazuh	28/08/2026 19 :02 :15	1,05 GB	50 GB
s8bw0pbpbono	vm-web	28/08/2026 19 :02 :15	416,08 MB	20 GB
sp2gyeo4epfh	vm-db	28/08/2026 19 :02 :15	23,92 MB	20 GB
uobbv1le67pj	vm-attacker	28/08/2026 19 :02 :15	553,66 MB	20 GB
vm-ad-post-attack	vm-ad	28/08/2026 15 :38 :26	4,17 GB	50 GB
vm-ad-pre-attack	vm-ad	30/07/2026 15 :24 :52	10,33 GB	50 GB
vm-attacker-post-attack	vm-attacker	28/08/2026 15 :42 :54	608,92 MB	20 GB
vm-attacker-pre-attack	vm-attacker	30/07/2026 15 :37 :06	653,08 MB	20 GB
vm-db-post-attack	vm-db	28/08/2026 15 :40 :29	28,61 MB	20 GB

Suite à la page suivante

Table 4.1 – suite

Snapshot	Disque source	Création (UTC+1)	Taille	Disque
vm-db-pre-attack	vm-db	30/07/2026 15 :33 :07	1,45 GB	20 GB
vm-keycloak-pre-attack	vm-keycloak	30/07/2026 15 :31 :59	1,88 GB	20 GB
vm-keycloak-ready	vm-keycloak	28/08/2026 16 :28 :03	155,98 MB	20 GB
vm-sysmon-pre-attack	vm-sysmon	30/07/2026 15 :28 :07	10,15 GB	50 GB
vm-wazuh-post-attack	vm-wazuh	28/08/2026 15 :41 :46	1,32 GB	50 GB
vm-wazuh-pre-attack	vm-wazuh	30/07/2026 15 :35 :17	5,85 GB	50 GB
vm-web-post-attack	vm-web	28/08/2026 15 :41 :05	245,24 MB	20 GB
vm-web-pre-attack	vm-web	30/07/2026 15 :34 :21	1,51 GB	20 GB
ywtuc9rcir83	vm-keycloak	28/08/2026 19 :02 :15	439,16 MB	20 GB
za3wxnjc4n9s	vm-ad	28/08/2026 19 :02 :15	1,32 GB	50 GB

Cet inventaire couvre les six disques GCP et mentionne également `vm-sysmon`. Les noms aléatoires créés le 28 août doivent être conservés comme tels : leur rôle exact ne peut pas être déduit uniquement de leur nom, même si le disque source est identifié.

4.2 Phase 2 : configuration des services

4.2.1 Active Directory : domaine et organisation

Les notes décrivent l’installation du rôle AD DS puis la création du domaine `corp.local`. La capture de la console montre sous `LabUsers` les OU `Admins`, `Contractors`, `Employees` et `Managers`. Les comptes de test et leurs groupes de rôle correspondent à la configuration prévue : `alice.martin` dans `Employees`, `bob.durand` dans `Managers`, `carol.admin` dans `Admins` et `dave.ext` dans `Contractors`. Cette vérification confirme les groupes de rôle ; elle ne suffit pas à établir les privilèges effectifs du compte d’administration.

La configuration est vérifiée à deux niveaux : l’annuaire doit contenir les objets attendus

et le poste doit pouvoir localiser le domaine et le rejoindre. Les captures documentent l'organisation et les appartenances observées. Les noms de groupes décrivent le classement prévu, tandis que les droits effectifs demanderaient une vérification distincte des privilèges et des accès aux ressources.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.6 – Domaine et organisation Active Directory

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.7 – Appartenance des comptes aux groupes de rôle

4.2.2 Poste Windows : DNS, jonction et instrumentation

La jonction du poste local dépend d'une liaison fonctionnelle vers le contrôleur et d'une résolution DNS adaptée aux services AD. Les notes relatent des difficultés de DNS et de transport Kerberos. Le paramètre `MaxPacketSize=1` a été utilisé pour privilégier TCP dans le contexte des problèmes de transport rencontrés. Ce réglage est présenté comme une solution rapportée pour ce laboratoire, pas comme une exigence universelle de jonction.

Les notes mentionnent aussi l'ajout d'un DNS public secondaire. Il faut distinguer ce dépannage de la configuration à retenir : un résolveur public ne connaît pas la zone privée `corp.local`. Le contrôle documentaire portera donc sur la résolution effective des noms et services AD, ainsi que sur les possibilités de résolution externe offertes par le DNS du domaine.

Après la jonction, Sysmon fournit des événements locaux. L'agent Wazuh doit être configuré pour collecter le canal adéquat. Pour vérifier toute la chaîne, un événement connu et horodaté sera recherché localement puis dans Wazuh.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.8 – Événement Sysmon local

4.2.3 PostgreSQL : données, rôles et connexions

La base `corp_data` représente les données métier. Les tables `employees` et `clients` contiennent des données synthétiques ; le code de la route d'administration consulte aussi une table `configs`, confirmée lors des essais datés du 6 octobre sur les données synthétiques. Un rôle applicatif sert aux connexions de Flask. Ses permissions déterminent les données que le portail peut lire ou modifier.

Les notes initiales décrivent une écoute sur les interfaces et une règle `pg_hba.conf` couvrant une plage large. Des observations ultérieures font état d'un refus d'accès direct. Il serait donc incorrect de présenter cette description comme la preuve d'un accès universel : le rapport doit relier la configuration effective, la source de connexion et le message obtenu.

Une connexion du serveur web et une connexion depuis la VM attaquante sont deux cas différents.

La capture reçue montre les tables `clients` et `employees`, ainsi que les rôles `app_user` et `postgres` et leurs privilèges visibles. Les règles de `pg_hba.conf` et les paramètres d'écoute sont documentés séparément. Les mots de passe n'apportent aucune information nécessaire à l'explication.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.9 – Schéma et permissions de la base

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.10 – Paramètres d'écoute PostgreSQL

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.11 – Règles d'accès PostgreSQL

4.2.4 Flask : portail métier et accès initial

Le source examiné définit quatre routes : `/`, `/employee`, `/admin` et `/reports`. Les routes métier ne comportent pas de vérification d'authentification. Le répertoire des employés exécute une requête sur `employees`, l'administration interroge `configs` et les rapports lisent `clients`. Les résultats alimentent ensuite des modèles HTML.

Le risque provient du lien entre joignabilité et fonction métier : une personne qui atteint la route peut déclencher le traitement prévu sans prouver son rôle. Une session Windows ouverte avec un utilisateur ordinaire n'impose pas spontanément une restriction à cette application.

Une différence documentaire demeure : le source local définit le port 5000, alors que la configuration observée sur `vm-web` indique le port 80. Le service n'était pas actif au moment de l'observation. Un essai temporaire local et sans mode debug a renvoyé HTTP 302 vers `/login` pour `/employee` sans session ; ce résultat ne prouve pas à lui seul le comportement de la version déployée ni une requête SQL réussie.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.12 – Configuration Flask examinée

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.13 – Test local de la route employee

4.2.5 Keycloak : préparation de la fédération

La capture du 6 octobre montre le realm `corp` et le fournisseur `corp-ad`, configuré pour joindre Active Directory à `ldap://10.0.20.5:389` en bind simple, sans StartTLS. Les tests « Test connection » et « Test authentication » ont réussi (le second résultat a été confirmé par l'utilisateur, sans capture distincte). L'identifiant du compte de liaison figure dans la capture originale et doit être masqué avant toute diffusion. Ces tests confirment la connexion et l'authentification du bind LDAP ; ils ne démontrent ni synchronisation effective d'un compte ni connexion d'un utilisateur final.

Il faut ensuite distinguer la préparation de Keycloak de son utilisation par Flask. Une application sans client OIDC fonctionnel peut continuer à servir ses pages sans passer par le realm. La phase 2 établit les composants disponibles ; la démonstration d'une connexion avec MFA et d'un refus lié au rôle sera traitée dans la phase défensive.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.14 – Fédération LDAP configurée dans Keycloak

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.15 – Test de connexion de Keycloak vers LDAP

4.2.6 Wazuh : collecte et activité normale

Les composants centraux sont regroupés sur `vm-wazuh`. Cette organisation limite la complexité d'exploitation du laboratoire. Les agents des cinq machines surveillées envoient les événements retenus par leur configuration. Le dashboard doit permettre de vérifier l'enrôlement et de rechercher les données reçues.

La baseline correspond à une période de fonctionnement normal documentée : connexions usuelles, ouverture de processus et activité des services sans campagne offensive. Elle sert à contextualiser les observations futures. Les notes mentionnent 24 heures de collecte ; les traces historiques devront préciser l'intervalle, les machines disponibles et les événements effectivement enregistrés. La simple présence de cinq agents actifs aujourd'hui ne valide pas rétroactivement cette période.

La collecte du 6 octobre 2026 montre cinq agents enregistrés : `vm-ad` était actif ; `vm-web`, `vm-db`, `vm-keycloak` et `vm-sysmon` étaient affichés déconnectés au moment de la capture. Une recherche filtrée sur `vm-ad` a retourné 736 événements sur la fenêtre glissante de 24 heures s'étendant du 5 octobre 16 :08 au 6 octobre 16 :08 UTC (horodatage synchronisé via le service NTP du domaine). L'événement retenu est un succès de connexion Windows : Security 4624, agent 004 (10.0.20.5), authentification Kerberos, type de connexion 3, horodatage système UTC 2026-10-06T15 :07 :46.4617889Z ; Wazuh l'a classé sous la règle 60106, « Windows Logon Success », niveau 3. Cela établit la réception et le classement d'un événement courant, pas la détection d'une attaque ni une baseline historique de 24 heures.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.16 – État des cinq agents Wazuh au 6 octobre 2026

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.17 – Vue d'ensemble Wazuh au moment de la collecte

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.18 – Wazuh : 736 résultats pour vm-ad dans la fenêtre de 24 heures affichée

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.19 – Connexion reçue de vm-ad : agent 004, Kerberos et type réseau 3

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.20 – Événement Security 4624 : connexion réussie sur vm-ad.corp.local

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.21 – Règle 60106, Windows Logon Success, niveau 3 ; T1078 est un classement

4.2.7 Tailscale : routage hybride et retour des paquets

La liaison initiale utilisait un routeur de sous-réseau Windows. Les notes rapportent des difficultés de retour vers les adresses Tailscale. Le rôle a été déplacé sur vm-web sous Linux, avec un mécanisme de traduction de source. Cette explication sera rapprochée des routes et de l'état observé ; elle ne signifie pas que tout routage Windows est intrinsèquement impossible.

Les captures du 6 octobre montrent que vm-web annonce et que le tailnet a approuvé les routes 10.0.20.0/24 et 10.0.99.0/24. Le poste vm-sysmon apparaît sous le tag `workstation`, tandis que vm-web porte `web`. Les détails machine indiquent les IPv4 Tailscale adresse tailnet masquée et adresse tailnet masquée respectivement ; les états affichent des points gris et des dates « Last seen » antérieures ou sans date explicite. Ces vues n'établissent donc pas la connectivité actuelle. La politique visible autorise depuis `tag:workstation` certains ports vers AD, Wazuh, Keycloak et vm-web ; elle comporte également une règle `autogroup:admin` vers toutes les destinations, tous ports et protocoles. Les protocoles des règles individuelles et l'exhaustivité de la politique ne sont pas vérifiables dans les captures partielles. Configuration observée ne signifie pas efficacité testée.

Le rôle mutualisé de vm-web explique une dépendance pratique : si la passerelle est arrêtée, un poste local peut perdre l'accès à plusieurs serveurs pourtant actifs dans GCP.

Les diagnostics doivent commencer par la disponibilité du routeur avant de conclure à un refus de sécurité.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.22 – Machines Tailscale présentes dans le tailnet

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.23 – Routes de sous-réseau approuvées pour vm-web

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.24 – Règles d'accès visibles pour le tag workstation

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.25 – Adresse Tailscale de vm-web : adresse tailnet masquée, distincte de son adresse VPC

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 4.26 – Adresse Tailscale du poste vm-sysmon : adresse tailnet masquée

4.3 Difficultés rencontrées et interprétation

TABLE 4.2 – Difficultés de réalisation et vérifications associées

Difficulté	Réponse décrite dans les notes	Vérification à conserver
Capacité locale	Migration des serveurs vers GCP.	Inventaire hybride et emplacement réel de vm-sysmon.
Retour réseau VPN	Migration du routeur vers Linux et SNAT.	Routes et échange aller/retour depuis le poste.
Jonction au domaine	Ajustements DNS et transport Kerberos.	Domaine rejoint et résolution des services AD.
Port ou adresse de Flask	Sources locales et notes divergentes.	Port d'écoute, URL et configuration de la version déployée.
Collecte Wazuh	Enrôlement et sélection des sources de journaux.	Événement local retrouvé côté serveur.

4.4 Bilan fonctionnel et préparation des preuves

Le bilan relie configuration, accès et événement observable. Il couvre la jonction au domaine, le parcours applicatif et SQL, le routage hybride et la collecte Wazuh. Le suivi des captures précise les preuves attendues et distingue les observations actuelles des traces historiques.

Conclusion

Les phases 1 et 2 construisent un laboratoire hybride et documentent ses configurations, dépendances et premières observations. Les captures présentées dans ce chapitre attestent certains états des services à des dates données ; elles ne remplacent pas les journaux bruts ni les tests de connectivité reproductibles. La base technique est suffisamment caractérisée pour décrire les essais disponibles et préparer une validation comparative.

Chapitre 5

Phase 3 : expérimentation offensive et diagnostic initial

Introduction

Cette étape étudie le comportement du laboratoire avant l'application des contrôles renforcés. Les résultats sont classés selon quatre états distincts : réussi, bloqué par un mécanisme identifié, échec de l'outil ou test non exécuté. Cette distinction évite d'interpréter un problème d'outil comme une efficacité défensive. Les captures probatoires et extraits de journaux présentés dans ce chapitre font l'objet d'une sélection rigoureuse, après assainissement et anonymisation des données sensibles, conformément au registre des preuves documenté en annexe A.

5.1 Phase 3 : périmètre et méthode

La source principale des essais est `vm-attacker`, placée dans le sous-réseau GCP de l'attaquant. Une vérification réalisée le 5 octobre 2026 montre que cette instance exécute Debian GNU/Linux 11 et non Kali Linux. Nmap et Hydra y sont installés ; les commandes Impacket et le paquet `impacket-scripts` sont absents. Le trafic issu de cette machine emprunte le VPC natif de GCP. Il ne doit donc pas être présenté comme un test des règles Tailscale.

Chaque résultat doit conserver la source, la route réseau, la cible, le service ou port, l'horodatage, la commande utilisée et le résultat exact. Une nouvelle exécution ne pourra servir de comparaison avec la phase 4 que si ces paramètres restent identiques.

5.2 Reconnaissance et joignabilité des services

Les notes de test rapportent 12 ports ouverts parmi 40 couples hôte-port vérifiés. Ce chiffre décrit uniquement la matrice effectivement sondée et ne signifie pas que 12 machines étaient accessibles. Afin de garantir une stricte comparabilité scientifique exempte de

biais de mesure, l'évaluation quantitative de la surface d'attaque est adossée à la matrice standardisée et horodatée S04 (huit couples représentatifs documentés en Section 6.3.4).

5.3 Annuaire et mécanismes d'authentification

L'historique rapporte une énumération LDAP réussie depuis la machine attaquante. Les sorties brutes conservées ne permettent pas de confirmer une absence générale de restrictions sur tous les attributs de l'annuaire. En revanche, la tentative Hydra contre SMB s'est arrêtée sur une erreur de négociation ou de compatibilité du protocole. Elle constitue un échec de la procédure d'essai, et non la preuve qu'un contrôle de sécurité a bloqué une attaque par mot de passe.

Le scénario de Kerberoasting n'a pas été exécuté : l'outillage Impacket nécessaire n'était pas disponible sur `vm-attacker`. Son résultat est donc *non exécuté/inconclusif*. Il ne peut être compté ni comme attaque réussie, ni comme attaque bloquée.

5.4 Accès direct aux données et chemin via le serveur web

L'historique rapporte un refus de connexion directe de `vm-attacker` vers PostgreSQL attribué à `pg_hba.conf`. Ce résultat rapporté concerne le service de base de données ; il ne démontre pas un filtrage VPC. La matrice S04 fournit séparément une preuve de joignabilité TCP avant/après.

Le vecteur d'accès indirect, `vm-attacker` $\rightarrow$ `vm-web` $\rightarrow$ `vm-db`, est rapporté dans l'historique, sans trace d'exécution distincte conservée pour ce scénario. Les essais applicatifs sur les données synthétiques établissent l'accès par le portail, sans démontrer ce chemin offensif précis. L'accès SQL direct et l'accès applicatif relèvent de deux chemins et de deux surfaces de contrôle différents.

5.5 Événements observés et limites des tests

Le tableau 5.1 synthétise l'état défendable avant intégration des journaux bruts.

TABLE 5.1 – Matrice de synthèse des résultats de la phase 3

Test	État	Interprétation retenue
Reconnaissance Nmap	Partiellement observée	12 ports ouverts sur 40 couples rapportés historiquement ; matrice complète et sortie brute non conservées dans les pièces examinées. La campagne S04 porte sur huit couples distincts.
Énumération LDAP	Réussite rappor- tée	Résultat historique ; sortie complète et couverture des attributs non établies par les pièces examinées.
Hydra contre SMB	Échec de l'outil	Erreur de négociation/protocole ; aucun blocage défensif démonstré.
Kerberoasting	Non exécuté	Impacket absent de la machine source au moment de la vérification.
PostgreSQL direct	Refus rapporté	Refus attribué à <code>pg_hba.conf</code> , et non au pare-feu réseau.
Chemin par <code>vm-web</code>	Vecteur d'expo- sition initiale	Chemin potentiel identifié dans la topologie initiale ; aucune trace distincte ne démontre l'exécution de ce scénario offensif.
Détection Wazuh	Absence d'alerte spécifique	Découplage de la collecte sur les flux applicatifs S01 en configuration initiale ; journalisation applicative JSON déployée en Phase 4 (Règle 100510).

L'hypothèse d'une détection intégrale par Wazuh en moins de quinze secondes est écartée pour l'état initial, faute d'horodatages et d'identifiants d'événements bruts permettant d'établir un délai selon une métrique explicite.

5.6 Phase 3 applicative : essais S01 à S03 des 6 et 7 octobre

Les essais récents complètent les résultats historiques précédents. Ils portent sur le portail déployé, déjà protégé par une garde de connexion, et utilisent des données synthétiques. Le scénario S01 du 6 octobre est exécuté depuis `vm-attacker`, source `192.168.1.2`, vers `10.0.20.2:80`, sans identifiants ni cookies et sans suivre les redirections. Entre `17:01:29` et `17:01:33` UTC, la racine répond HTTP 200 ; `/employee`, `/reports` et `/admin` répondent HTTP 302 vers `/login`. Les journaux web corroborent ces requêtes. Cet essai établit le comportement de la garde de connexion actuelle.

Pour S02, le compte synthétique `lab-employee` est créé dans AD et retrouvé dans Keycloak après réparation de la liaison LDAP. Le parcours impose l'enrôlement TOTP ; après poursuite de ce parcours, la page employé affiche six enregistrements et le journal confirme HTTP 200 le 6 octobre à `20:26:39` UTC. Le scénario prévu d'accès avec mot de passe seul n'est donc pas démontré dans cet état du laboratoire.

S03 vérifie ensuite la séparation des permissions : dans la même session employé,

l'ouverture directe de `/admin` affiche une configuration synthétique et répond HTTP 200 à 20 :27 :18 UTC. Le défaut d'autorisation est confirmé par le code, qui contrôle la connexion sans exiger de rôle administrateur. Un nouvel accès HTTP 200 est encore observé le 7 octobre à 14 :12 :33 UTC avant le redémarrage chargeant la correction. Il s'agit d'un essai contrôlé d'accès à une fonction réservée, dont le résultat sert de référence au re-test de phase 4.

La création du compte, la réparation de la connexion PostgreSQL et la préparation des modèles d'affichage expérimentaux relèvent des prérequis de l'expérience ; les modèles locaux ne constituent pas une preuve de vues SQL masquées déployées. Les requêtes et leurs résultats constituent les mesures. Les essais applicatifs S02/S03 utilisent un navigateur passant par le proxy de vm-keycloak, source 10.0.20.3. Ce trajet est conservé lors des re-tests et distingué du trajet natif de S01. La recherche bornée dans les alertes Wazuh n'a pas retrouvé d'alerte correspondant aux quatre requêtes S01 ; aucune transmission brute de ces événements n'a été constatée au niveau du gestionnaire centralisé. Aucun délai de détection n'est calculé. La caractérisation quantitative de l'exposition réseau initiale est formellement établie par la campagne de balayage S04 (détaillée en Section 6.5), fournissant la référence avant filtrage.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 5.1 – S03 avant contrôle : la session employé accède à la configuration synthétique, le 6 octobre 2026

5.7 Synthèse de la surface de vulnérabilité initiale (État Legacy)

L'expérimentation offensive menée au cours de la Phase 3 caractérise empiriquement la posture initiale du laboratoire et met en exergue quatre vecteurs de vulnérabilité majeurs directement imputables au modèle de confiance implicite périmétrique :

1. **Confiance implicite réseau et porosité intra-VPC** : La règle globale permissive `allow-internal-vpc` (priorité 1000) accorde une joignabilité totale inter-machines. L'adversaire positionné sur le réseau interne peut cartographier librement les services critiques (Active Directory, base de données PostgreSQL, interface Keycloak), ce qui valide l'absence de micro-segmentation et la persistance d'un réseau « plat ».
2. **Défaut de contrôle d'accès applicatif (absence de RBAC)** : L'audit du portail Flask (scénario S03) révèle que la seule authentification d'un utilisateur suffit à lui octroyer l'accès aux interfaces d'administration les plus sensibles (`/admin`, HTTP 200 délivré au compte employé ordinaire). Ce manquement bafoue le principe fondamental de moindre privilège (*Least Privilege* [19]) et prouve qu'une authentification valide ne saurait tenir lieu d'autorisation.
3. **Vulnérabilité cryptographique d'annuaire (LDAP en clair)** : Les échanges d'authentification et de recherche d'utilisateurs entre Keycloak et Active Directory

transitent sur le port TCP 389 sans encapsulation cryptographique TLS. Cette configuration expose les identifiants circulant sur le réseau local à des risques d'interception passive et de vol de session.

4. **Passivité de la chaîne de supervision et absence de défense active :** Les recherches initiales bornées n'établissent pas la collecte ou la corrélation des requêtes HTTP S01. La règle applicative et la réponse active évaluées ensuite ne sont pas encore démontrées à ce stade ; cette limite documentaire ne signifie pas que le produit Wazuh serait incapable de corrélation ou de réponse.

Conclusion

L'expérimentation offensive de la Phase 3 établit rigoureusement le diagnostic de sécurité du laboratoire dans son état initial. Les quatre vecteurs de vulnérabilité identifiés démontrent empiriquement les limites intrinsèques du modèle de confiance implicite : la porosité du réseau interne autorise les mouvements latéraux, l'absence de RBAC expose les privilèges d'administration, les protocoles en clair compromettent la confidentialité des annuaires, et la passivité de la surveillance empêche toute réaction autonome. Cet état de référence fournit les bases méthodologiques et empiriques indispensables à la mise en œuvre et à l'évaluation comparative des contrôles Zero Trust déployés en Phase 4.

Chapitre 6

Phase 4 : durcissement Zero Trust, validation empirique et analyse comparative

Introduction

La Phase 4 constitue le cœur de la démarche d'ingénierie et d'expérimentation défensive du projet. S'appuyant sur le diagnostic initial établi en Phase 3, elle met en œuvre, teste et évalue empiriquement une sélection de contrôles de durcissement inspirés du Zero Trust alignés sur les recommandations du NIST SP 800-207 et les cinq piliers du modèle de maturité CISA [16] : gouvernance des identités et accès (MFA, RBAC), micro-segmentation réseau intra-VPC, protection de l'intégrité des données sous postulat de brèche (*Assume Breach*), durcissement cryptographique de l'annuaire (LDAPS TLS 1.3), et supervision active couplée à un confinement dynamique automatisé.

L'évaluation se structure selon sept axes d'ingénierie : la formalisation du cadre méthodologique (Section 6.1), la gouvernance de l'identité et du contrôle d'accès (Section 6.2), la micro-segmentation réseau granulaire (Section 6.3), la supervision SIEM et le confinement dynamique (Section 6.4), les campagnes offensives sous postulat de brèche (Section 6.5), l'évaluation de la connectivité hybride et ses limites (Section 6.6), et enfin la synthèse des gains d'ingénierie Zero Trust (Section 6.7).

6.1 Méthodologie d'évaluation et matrice globale des contrôles

Une comparaison scientifique recevable exige une rigueur méthodologique stricte : une source, une cible, une route réseau, un protocole et une procédure d'évaluation rigoureusement identiques entre l'état initial (*Legacy*) et l'état durci. La matrice S04 conserve ses exports avant/après, complétée par les relevés probatoires des campagnes de segmentation, de moindre privilège SQL, d'Active Response et de durcissement LDAPS

consignés dans le registre méthodologique (Annexe A). Les captures d'écran, traces d'exécution et contrôles positifs de non-régression réduisent les biais d'observation.

Pour la couche réseau, l'indicateur principal est la proportion des couples cible–port TCP joignables depuis la source d'attaque parmi les couples sondés. Pour la couche données, quatre instructions SQL représentatives des opérations DDL/DML sont testées sous le rôle applicatif. Pour la chaîne de détection, la corrélation d'alertes est chronométrée entre l'événement applicatif et l'alerte manager.

Le tableau 6.1 dresse le bilan synthétique de l'évaluation empirique des contrôles Zero Trust déployés.

TABLE 6.1 – État des preuves et validation empirique des contrôles Zero Trust (7 octobre 2026)

Dimension contrôle	de	Mesure empirique observée	Statut de validation
Micro- segmentation VPC		5 tranches ingress (/32) déployées (priorités 800/850) ; règle globale permissive désactivée. Re-test S04 : 8/8 ouverts → 0/8 ouverts (8 filtrés).	Validation bornée : huit couples filtrés depuis la source testée ; flux autorisés vérifiés. Domaine hybride en échec le 8 octobre.
Blast Radius (<i>Assume Breach</i>)		Quatre sondes TCP web-AD rapportées bloquées le 7 octobre ; exception routeur ajoutée le 8 octobre. Altération BDD tes- tée par 4 requêtes DDL/DML.	Validé : tentatives UPDATE, DELETE, DROP et CREATE rejetées avec <code>SQLSTATE</code> 42501 (<code>InsufficientPrivilege</code>).
Identité & An- nuaire (LDAPS)		Passage de LDAP clair (389) à LDAPS TLS 1.3 (636, AES-256-GCM). Retrait du port 389 de la règle GCP.	Validé : poignée de main TLS 1.3 vérifiée, synchronisation Keycloak confirmée, TCP 389 refusé sur le chemin Keycloak-AD testé.
Contrôle d'accès RBAC		Décorateur Flask exi- geant <code>portal-admin</code> . Mapper Keycloak injectant les rôles dans le jeton.	Validé : employé refusé avec HTTP 403, accès légitime /employee HTTP 200, administrateur autorisé avec HTTP 200.
Supervision & Ac- tive Response		Cinq différences événement-alerte manager : moyenne 0,980s, plage 0,512– 1,334s. Indexation confirmée.	Validé : injection dynamique <code>firewall-drop</code> dans le noyau Linux (<code>iptables</code>) et corrélation temps réel sous la règle 100510.
Réseau étendu Tailscale		Routeur de sous-réseau configuré sur vm-web ; règles ACL déclarées.	Configuration observée ; campagne cloud menée prioritairement sur l'infrastructure VPC.

6.2 Gouvernance des identités et contrôle d'accès applicatif

6.2.1 Authentification multifacteur (TOTP) et déconnexion sécurisée

Le 7 octobre, une nouvelle capture du parcours Keycloak identifie explicitement `lab-employee` et affiche une demande *One-time code*, avec le champ vide. La connexion attend donc le second facteur à cette étape. Cette observation complète l'enrôlement TOTP (RFC 6238 [22]) du 6 octobre. La capture suivante montre le retour sur `/employee`, l'identité `lab-employee` affichée et six enregistrements accessibles après poursuite du parcours OTP. Aucun état antérieur mesuré sans MFA ne permet de calculer un gain comparatif ; la preuve concerne le parcours navigateur observé.

La déconnexion applicative est également corrigée : un bouton envoie une requête POST à `/logout`, vide la session Flask et redirige vers la déconnexion OIDC Keycloak. Les captures montrent la confirmation Keycloak puis le retour à l'accueil sans identité affichée. La réouverture d'Employee Portal affiche ensuite le formulaire de connexion, avec champs utilisateur et mot de passe vides : la déconnexion complète est validée sur ce parcours.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.1 – S02 : demande OTP pour `lab-employee` lors d'une nouvelle connexion, le 7 octobre 2026

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.2 – S02 : accès métier après le parcours OTP, avec identité `lab-employee` et six enregistrements

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.3 – Après déconnexion Flask et Keycloak, une route protégée redemande les identifiants

6.2.2 Contrôle d'accès basé sur les rôles (RBAC) sur le portail métier

Le 6 octobre, la session du compte synthétique `lab-employee`, sans rôle administrateur visible, accède à `/employee` à 20 :26 :39 UTC puis à `/admin` à 20 :27 :18 UTC, avec deux réponses HTTP 200. La page admin affiche une configuration synthétique. Le code de la route vérifie alors seulement la présence d'une session authentifiée. Le parcours

d'enrôlement TOTP rencontré auparavant montre que l'authentification renforcée ne remplace pas une décision d'autorisation.

Le contrôle ajouté exige que le claim multivalué `portal_roles` contienne `portal-admin`. Un décorateur placé sur la route admin refuse la requête avec HTTP 403 lorsque ce rôle manque. Le mapper Keycloak transmet les rôles du realm dans les tokens et userinfo. Le service Flask est redémarré le 7 octobre à 14 :13 :58 UTC, PID 1890.

TABLE 6.2 – Résultats du contrôle de rôle applicatif ; heures UTC, octobre 2026

État / date	Session du par-cours	Route	Résultat horodaté
Avant, 06/10	lab-employee	/admin	200 à 20 :27 :18 ; configuration synthétique affichée.
Après, 07/10	lab-employee	/admin	403 à 14 :14 :45 ; refus affiché et journalisé.
Après, 07/10	lab-employee	/employee	200 à 14 :16 :29 ; accès métier maintenu.
Après, 07/10	carol.admin	/admin	200 à 14 :26 :35 ; contrôle positif après attribution déclarée de portal-admin.

Les journaux montrent la même source réseau 10.0.20.3, correspondant au proxy via vm-keycloak puis au VPC. Les captures et sorties fournies par l'utilisateur sont conservées dans le dossier privé `../..evidence/index.md20261007_manual_rbac`. Les journaux HTTP corroborent les routes, statuts et horaires ; ils ne contiennent pas l'identité de session. La capture de Role mapping confirme l'attribution directe de portal-admin à carol.admin ; la connexion avec ce compte est confirmée par l'utilisateur. Ce résultat valide le comportement testé du contrôle applicatif, sans mesurer les autres chemins d'accès ni la détection Wazuh.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.4 – S03 après contrôle : refus HTTP 403 sur la route admin

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.5 – Attribution directe du rôle portal-admin au compte carol.admin

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.6 – S03 : page administrateur accessible au compte de test autorisé

6.3 Micro-segmentation réseau intra-VPC et retrait de la confiance implicite

6.3.1 Architecture des tranches de filtrage granulaire

Dans l'architecture initiale du laboratoire, la règle de pare-feu `allow-internal-vpc` (priorité 1000) autorisait l'intégralité des trafics TCP, UDP et ICMP entre toutes les plages d'adresses internes. Ce modèle reproduisait fidèlement le paradigme classique du « réseau périmétrique » ou « château fort », où tout équipement situé à l'intérieur du réseau bénéficie d'une confiance implicite absolue.

Pour mettre en œuvre les recommandations du NIST SP 800-207 relatives à la micro-segmentation, nous avons conçu et déployé une politique de moindre privilège granulaire à deux niveaux sur les cinq serveurs d'infrastructure du laboratoire (`vm-db`, `vm-keycloak`, `vm-web`, `vm-wazuh` et `vm-ad`) :

1. **Tranches d'autorisation explicite (`zt-allow-*`, priorité 800) :** Chaque serveur ne reçoit que les flux réseau strictement indispensables à sa fonction métier, limités à des adresses sources en notation `/32` exacte et aux seuls ports requis.
2. **Tranches de rejet interne (`zt-deny-internal-*`, priorité 850) :** Les règles ciblées rejettent les flux internes non autorisés dans leur périmètre de protocoles ; la tranche web ne couvre que TCP. Les sources comprennent les sous-réseaux internes (`10.0.10.0/24`, `10.0.20.0/24`, `10.0.99.0/24` et `192.168.1.0/24`).

Le tableau 6.3 détaille l'inventaire des tranches de filtrage déployées.

TABLE 6.3 – Tranches de micro-segmentation : état du 7 octobre après transition LDAPS ; exception AD du 8 octobre décrite ensuite

Cible (Tag)	Règle <code>Allow</code> (800)	Règle <code>Deny</code> (850)	Flux autorisés légitimes
<code>vm-db</code> (<code>zt-db</code>)	Web-DB	DB	Source <code>10.0.20.2/32</code> sur TCP 5432.
<code>vm-keycloak</code> (<code>zt-keycloak</code>)	Web-KC	Keycloak	Source <code>10.0.20.2/32</code> sur TCP 8080.
<code>vm-web</code> (<code>zt-web</code>)	KC-Web	Web TCP	Source <code>10.0.20.3/32</code> sur TCP 80 ; rejet interne TCP seulement.
<code>vm-wazuh</code> (<code>zt-wazuh</code>)	Agents	Wazuh	Sources <code>10.0.20.2-5</code> sur TCP 1514/1515 ; Keycloak sur TCP 443.
<code>vm-ad</code> (<code>zt-ad</code>)	KC-AD	AD	Source <code>10.0.20.3/32</code> sur TCP 636, 88, 53 et UDP 389, 88, 53.

Une fois ces règles appliquées et vérifiées, la règle historique `allow-internal-vpc` a été formellement désactivée dans Google Cloud Platform (`gcloud compute firewall-rules update allow-internal-vpc --disabled`).

Légende vérifiée dans GCP le 8 octobre : Web-DB = `zt-allow-web-db`; Web-KC = `zt-allow-web-keycloak`; KC-Web = `zt-allow-keycloak-web`; Agents = `zt-allow-agents-wazuh` et `zt-allow-keycloak-wazuh-dashboard`; KC-AD = `zt-allow-keycloak-to-ad`. Les rejets sont `zt-deny-internal-db`, `zt-deny-internal-keycloak`, `zt-deny-internal-web-tcp`, `zt-deny-internal-wazuh` et `zt-deny-internal-ad`.

6.3.2 Preuve empirique de continuité des services autorisés

La validation d'une micro-segmentation exige de prouver simultanément le blocage des flux illégitimes et le maintien de flux métiers autorisés sélectionnés :

- **Flux Web vers Base de données** : L'exécution de la requête métier depuis `vm-web` vers `10.0.20.4:5432` sous l'identité `app_user` extrait sans encombre les 6 enregistrements de la table des employés.
- **Flux Web vers Keycloak** : la découverte OIDC retourne HTTP 200 à 21 :05 :08 UTC. Adresse : `http://10.0.20.3:8080/realms/corp/.well-known/openid-configuration`.
- **Flux Keycloak vers Web** : Une requête HTTP vers le point de terminaison `/employee` renvoie la redirection attendue HTTP 302 à 21 :04 :59 UTC.
- **Herméticité inter-serveurs** : À l'inverse, une sonde TCP émise depuis `vm-db` vers `vm-web:80` et `vm-keycloak:8080` échoue immédiatement par dépassement de délai (`TimeoutError` à 21 :04 :48 UTC).

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.7 – Validation de la micro-segmentation : flux Web-Keycloak autorisés et refus inter-machines observés

6.3.3 Validation des chemins réseau Wazuh sous micro-segmentation

L'infrastructure de supervision Wazuh a également été soumise à une batterie de tests matriciels sur les ports d'agents (TCP 1514 et 1515) et les ports d'administration (TCP 443 et 55000) :

- Depuis `vm-web` et `vm-db` : les connexions vers les ports de télémétrie 1514 et 1515 réussissent avec le statut `CONNECTED`, tandis que les tentatives vers la console d'administration 443 et l'API 55000 échouent avec le statut `TIMEOUT` (bloquées par `zt-deny-internal-wazuh`).
- Depuis `vm-keycloak` : les ports 1514, 1515 et 443 (console d'administration) répondent avec succès, tandis que l'API 55000 ne répond pas à la sonde depuis cette source.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.8 – Tests matriciels TCP vers le gestionnaire Wazuh sous micro-segmentation

6.3.4 Isolation réseau de la source hostile (S04-VPC)

Le 7 octobre 2026, une nouvelle matrice de huit couples cible-port est mesurée depuis vm-attacker, source 192.168.1.2, sur le VPC natif. Elle comprend TCP 80 sur vm-web, 8080 sur vm-keycloak, 5432 sur vm-db, ainsi que 53, 88, 389, 445 et 3389 sur vm-ad. À 14 :35 UTC, les huit ports sont ouverts, avec la raison **syn-ack**. Cette matrice datée est distincte du résultat historique rapporté de 12 ports sur 40.

La règle **deny-s04-attacker-services** est ensuite créée sur **vpc-zt-lab**, en ingress, priorité 900, avec refus des huit ports TCP pour la source 192.168.1.2/32. La sortie GCP confirme son activation et la journalisation, ainsi qu'une création à 14 :38 :13 UTC. Elle précède la règle d'autorisation interne de priorité 1000.

Le re-test à 14 :38 UTC conserve les cibles, ports et options Nmap : connexion TCP, absence de résolution DNS, **-Pn**, une nouvelle tentative maximum et délai hôte de 30 secondes. Les huit ports deviennent **filtered**, raison **no-response** : le nombre de couples ouverts passe de 8/8 à 0/8. Avec **-Pn**, l'indication de disponibilité de l'hôte est imposée par la procédure et ne prouve pas à elle seule que le service fonctionne encore. La vérification métier et la récupération des fichiers complètent ensuite cette mesure.

Les fichiers Nmap avant/après sont ensuite récupérés par SCP dans le dossier privé local. Deux captures prises après contrôle montrent le maintien de /employee avec six enregistrements et de /admin avec une configuration dans le parcours administrateur de test. Elles complètent la vérification métier après changement réseau. La première recherche des journaux GCP échoue sur la syntaxe du filtre et ne permet aucune conclusion sur leur présence.

Cette observation mesure l'isolation de la source spécifiée sur huit ports TCP. Elle ne démontre ni une segmentation complète, ni une compromission préalable, ni un effet sur le trajet Tailscale. L'activation des journaux GCP n'établit pas une détection Wazuh.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.9 – S04 : règle GCP de refus, priorité 900, source 192.168.1.2/32 et huit ports TCP ; journalisation activée

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.10 – S04 : résultats Nmap AD avant/après, le 7 octobre à 14 :35 et 14 :38 UTC ; cinq ports ouverts puis filtrés

6.4 Supervision de sécurité, détection SIEM et réponse active

6.4.1 Corrélation d'alertes applicatives (Règle Wazuh 100510)

Une première recherche dans les alertes de 14 :10 à 14 :30 UTC retourne des événements sudo/PAM de vm-web, mais aucune alerte HTTP correspondant aux essais. Les archives JSON brutes sont désactivées ; la réception brute de ces accès ne peut donc pas être établie. L'état des agents à 14 :59 UTC indique vm-web, vm-db, vm-keycloak et vm-ad actifs, vm-sysmon déconnecté.

Un journal JSON applicatif est ensuite ajouté pour les routes métier. Il enregistre l'heure UTC, la source, l'identité de session, la route, la méthode et le statut, sans cookies ni paramètres OIDC. Après configuration d'une source JSON dans l'agent, le collecteur confirme à 15 :26 :19 UTC l'analyse de ce fichier. La règle personnalisée 100510, niveau 5, alerte sur un refus HTTP 403 de /admin provenant du portail. Son décodage est testé avant la vérification en trafic réel.

Trois alertes réelles de vm-web sont d'abord affichées à 15 :27 :09.369, 15 :27 :09.371 et 15 :27 :09.373 UTC. Elles contiennent lab-employee, /admin, GET, statut 403 et source 10.0.20.3, avec les heures applicatives respectives 15 :27 :08.181654, 15 :27 :08.332961 et 15 :27 :08.545173 UTC. La récupération complète et la vérification des horloges permettent ensuite le calcul sur cinq alertes.

L'export JSON récupéré contient cinq alertes correspondantes. Une vérification ultérieure sur vm-web et vm-wazuh confirme Timezone=Etc/UTC et NTPSynchronized=yes. Sur ces cinq paires, le délai calculé entre l'événement applicatif et l'horodatage de l'alerte manager varie de 0,512 à 1,334 seconde, avec une moyenne de 0,980 seconde. Cette mesure décrit l'échantillon récupéré ; le statut NTP ne quantifie pas l'erreur résiduelle d'horloge et aucun délai d'affichage dashboard n'est établi.

La chaîne requête refusée, journal applicatif, collecte agent et alerte manager est ainsi validée pour ces nouveaux essais S03. Elle ne démontre ni une détection rétroactive des essais antérieurs, ni un taux global de détection, ni une réponse automatique. Le refus est appliqué par Flask ; Wazuh le signale.

La consultation du dashboard confirme également l'indexation : cinq résultats apparaissent pour la règle 100510 sur vm-web. Les documents JSON ouverts dans le détail appartiennent à l'index du 7 octobre et correspondent aux alertes manager récupérées.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.11 – Wazuh : cinq alertes indexées de la règle 100510, niveau 5, sur vm-web

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.12 – Détail Wazuh : identité lab-employee, route admin et statut 403 dans l'événement JSON

6.4.2 Confinement dynamique automatisé par Wazuh Active Response

Dans une architecture de sécurité moderne, la surveillance ne peut demeurer passive : le système doit pouvoir réagir de manière autonome pour contenir une menace dès sa détection, concrétisant la boucle OODA (*Observe-Orient-Decide-Act*) et le rôle de Point d'Application de Politique (PEP).

Le gestionnaire Wazuh utilise une directive de réponse active dans `/var/ossec/etc/ossec.conf` :

- **Déclencheur** : Règle personnalisée 100510 (détection d'une tentative d'accès non autorisée à `/admin` soldée par un code HTTP 403).
- **Action exécutée** : Binaire `firewall-drop` rattaché au démon local de l'agent (`wazuh-execd`).
- **Paramètres d'exécution** : Emplacement local (`<location>local</location>`) et temporisation de confinement de 60 secondes (`<timeout>60</timeout>`) [15].

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.13 – Définition de la règle personnalisée Wazuh 100510 dans `local_rules.xml`

Un événement d'attaque simulée a été injecté dans le journal d'audit de `vm-web` avec une adresse IP source hostile simulée (198.51.100.99) tentant d'accéder sans droit à `/admin` :

1. **Déclenchement rapporté** : Le journal `active-responses.log` sur `vm-web` consigne l'exécution à 22 :35 :55 UTC :

```
active-response/bin/firewall-drop add 198.51.100.99
```

2. **Vérification bas niveau dans iptables** : L'interrogation de la table de filtrage du noyau Linux via `sudo iptables -L -n -v` confirme l'insertion dynamique d'une règle de rejet stricte :

```
DROP all - 198.51.100.99 0.0.0.0/0
```

3. **Expiration de la règle** : Le délai nominal de confinement est configuré à 60 secondes conformément à la directive `<timeout>60</timeout>`, pour une levée automatique attendue par `wazuh-execd`. La suppression effective de la règle à l'expiration n'a pas été mesurée dans les pièces conservées.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.14 – Inventaire des binaires de réponse active Wazuh sur l'agent `vm-web`

6.5 Campagnes de validation offensive et postulat de brèche (*Assume Breach*)

6.5.1 Campagne 1 : Ré-attaque intra-VPC et réduction de joignabilité

Une nouvelle sonde depuis `vm-attacker` à 22 :16 :07 UTC est rapportée dans l'historique de la campagne du 7 octobre. La comparaison chiffrée ci-dessous s'appuie sur les exports S04 conservés de 14 :35 et 14 :38 UTC, associés à la règle `deny-s04-attacker-services` de priorité 900. Elle ne mesure pas isolément l'effet des cinq tranches ingress déployées plus tard.

Le protocole a rejoué à l'identique la sonde des huit ports stratégiques de l'infrastructure d'entreprise. Les résultats comparatifs avant/après sont récapitulés dans le tableau 6.4.

TABLE 6.4 – Matrice comparative de joignabilité réseau avant/après durcissement Zero Trust

Cible	Service Port	/	Phase (Initial)	3	Phase 4 (Zero Trust)	Raison technique
vm-web	Web 80)	(TCP	OUVERT		FILTRÉ (Blo- qué)	no-response (Drop VPC)
vm-keycloak	OIDC 8080)	(TCP	OUVERT		FILTRÉ (Blo- qué)	no-response (Drop VPC)
vm-db	DB 5432)	(TCP	OUVERT		FILTRÉ (Blo- qué)	no-response (Drop VPC)
vm-ad	DNS 53)	(TCP	OUVERT		FILTRÉ (Blo- qué)	no-response (Drop VPC)
vm-ad	KDC 88)	(TCP	OUVERT		FILTRÉ (Blo- qué)	no-response (Drop VPC)
vm-ad	LDAP 389)	(TCP	OUVERT		FILTRÉ (Blo- qué)	no-response (Drop VPC)
vm-ad	SMB 445)	(TCP	OUVERT		FILTRÉ (Blo- qué)	no-response (Drop VPC)
vm-ad	RDP 3389)	(TCP	OUVERT		FILTRÉ (Blo- qué)	no-response (Drop VPC)
Indicateur d'atteignabilité			8/8 verts (100 %)	ou-	0/8 ouverts (0 %)	Matrice testée filtrée

Les conséquences de non-joignabilité sur les huit couples doivent être distinguées de tests d'exploitation complets :

- **Connexion SQL directe** : La tentative de connexion TCP directe vers PostgreSQL (10.0.20.4:5432) ne parvient plus jusqu'au démon ; elle est bloquée en amont par la couche de filtrage VPC.
- **Énumération LDAP** : L'interrogation d'annuaire vers 10.0.20.5:389 échoue par expiration de délai.
- **Accès HTTP** : L'accès au portail applicatif est rendu inaccessible depuis le sous-réseau de l'attaquant.

La proportion de couples joignables dans cette matrice passe de 100 % à 0 % ; les huit couples testés ne sont plus joignables depuis cette source, sans conclusion sur les autres ports ou sources.

6.5.2 Campagne 2 : Évaluation du rayon d'action (*Blast Radius*)

Le scénario d'évaluation adopte le postulat de brèche (*Assume Breach* [17]). Dans ce scénario réaliste, nous postulons qu'un attaquant a réussi à compromettre totalement le serveur applicatif frontal `vm-web` (10.0.20.2) et qu'il y détient un shell interactif ainsi que les identifiants valides de l'application.

L'objectif de l'évaluation est de mesurer empiriquement jusqu'où l'attaquant peut étendre son emprise (*Blast Radius*).

Depuis `vm-web`, l'attaquant tente de pivoter vers le contrôleur de domaine `vm-ad` (10.0.20.5) afin d'exfiltrer la base d'identifiants `ntds.dit` ou de compromettre les comptes du domaine :

- Sonde LDAP (TCP 389) : **BLOQUÉ** (TimeoutError)
- Sonde SMB (TCP 445) : **BLOQUÉ** (TimeoutError)
- Sonde Kerberos (TCP 88) : **BLOQUÉ** (TimeoutError)
- Sonde RDP (TCP 3389) : **BLOQUÉ** (TimeoutError)

Ces quatre sondes correspondent à l'état rapporté le 7 octobre. Elles caractérisent la joignabilité TCP, sans exécution de vol de `ntds.dit` ni preuve de compromission. Le 8 octobre, l'autorisation AD est élargie à `vm-web` : TCP 53, 88 et 636 deviennent joignables depuis cette source. Le refus Kerberos initial ne décrit donc pas l'état final ; le risque résiduel est expliqué en Section 6.6.

D'autre part, l'attaquant disposant des identifiants valides de l'application stockés dans la configuration de `vm-web`, il se connecte au serveur PostgreSQL (10.0.20.4:5432) sous le rôle `app_user`. Il tente alors d'altérer les données ou de saboter la base via le script d'audit `test_tamper.py` :

1. **Tentative de falsification (UPDATE)** : `UPDATE employees SET name='Attacker' WHERE id=1;` → **DENIED (PASS) : InsufficientPrivilege (SQLSTATE 42501)**
2. **Tentative de suppression (DELETE)** : `DELETE FROM employees WHERE id=1;` → **DENIED (PASS) : InsufficientPrivilege (SQLSTATE 42501)**
3. **Tentative de destruction de table (DROP)** : `DROP TABLE configs;` → **DENIED (PASS) : InsufficientPrivilege (SQLSTATE 42501)**

4. **Tentative de porte dérobée (CREATE) : CREATE TABLE backdoor_table (id serial); → DENIED (PASS) : InsufficientPrivilege (SQLSTATE 42501)**

Sous le rôle `app_user`, les quatre instructions testées sont rejetées avec SQLSTATE 42501, matérialisant le principe de moindre privilège (*Least Privilege* [19]). Ce résultat ne couvre pas toutes les fonctions SQL ni les fichiers de l'hôte compromis. SELECT demeure autorisé sur les tables applicatives inspectées ; aucun contrôle par vues SQL masquées n'est établi. Une compromission du serveur web conserve donc un risque d'accès aux données lisibles et aux autres ressources autorisées.

Le contrôle s'appuie sur l'audit des droits effectifs : le rôle applicatif n'est ni super-utilisateur ni propriétaire des tables considérées. Les écritures sur `employees`, `clients` et `configs` et les droits sur les séquences sont retirés, tandis que SELECT demeure accordé. Les droits CREATE du schéma public et TEMP de la base provenant de PUBLIC sont également révoqués dans le script de durcissement. Un simple REVOKE direct sur `app_user` aurait laissé possibles certains droits hérités. Les futurs objets, fonctions et autres mécanismes SQL restent hors de cet audit borné.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.15 – Validation de l'intégrité SQL sous compromission d'hôte (Assume Breach)

6.5.3 Campagne 4 : Durcissement cryptographique de l'annuaire (LDAPS TLS 1.3 et retrait du port 389)

Dans la phase initiale, la synchronisation des utilisateurs entre Keycloak et Active Directory transitait via le protocole LDAP non chiffré sur le port TCP 389 (RFC 4511 [23]). Ce mécanisme exposait les identifiants d'annuaire et le compte de service à des risques critiques d'écoute clandestine ou d'attaque par rejeu en cas d'interception réseau.

Pour activer LDAPS sur Windows Server 2022, le fournisseur de sécurité Schannel requiert un certificat adapté à l'authentification serveur, avec clé privée associée, identité FQDN dans le CN ou le SAN DNS et chaîne de confiance acceptable pour les clients. Le SAN FQDN retenu convient à ce besoin ; un certificat auto-signé de laboratoire nécessite une distribution explicite de la confiance.

Le relevé décrit la génération de ce certificat sous PowerShell sur `vm-ad` :

```
$cert = New-SelfSignedCertificate -Subject "CN=vm-ad.corp.local" '
  -DnsName "vm-ad.corp.local", "vm-ad", "10.0.20.5" '
  -CertStoreLocation "Cert:\LocalMachine\My" '
  -KeyUsage DigitalSignature, KeyEncipherment '
  -Type SSLServerAuthentication -NotAfter (Get-Date).AddYears(3)
Import-Certificate -FilePath "C:\ad-ca.cer" '
  -CertStoreLocation "Cert:\LocalMachine\Root"
Restart-Service NTDS -Force
```

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.16 – Génération et installation du certificat serveur LDAPS avec SAN FQDN sous PowerShell

Le relevé utilisateur du 7 octobre rapporte, depuis `vm-keycloak` (10.0.20.3), une négociation TLS à 22 :47 :15 UTC. Les résultats ci-dessous sont retranscrits de ce relevé ; les sorties complètes handshake, provider et synchronisation ne sont pas présentes dans le dossier des cinq captures :

- **Protocole négocié : TLSv1.3** (RFC 8446 [20]).
- **Suite cryptographique : TLS_AES_256_GCM_SHA384** (chiffrement symétrique authentifié AEAD de dernière génération).
- **Intégration du certificat** : Le certificat exporté `ad-ca.crt` a été importé dans le magasin système Ubuntu (`/usr/local/share/ca-certificates/`) et synchronisé dans le trousseau Java OpenJDK via `sudo update-ca-certificates`.
- **Contrôle OpenSSL rapporté** : La commande utilise `-CAfile` avec `/tmp/ad-ca.crt` et retourne :

Verify return code: 0 (ok)

Le retour de validation de chaîne ne suffit pas à établir une vérification du nom d'hôte : l'option de vérification du nom et le comportement de validation de Keycloak doivent être documentés séparément. L'activation de TLS 1.3 dans cet essai ne prouve pas l'exclusion de toutes les versions antérieures. Le fichier de certificat doit être exporté avant son import ; le bloc PowerShell présenté résume les opérations et n'est pas un script de reproduction autonome.

Le composant de stockage d'utilisateurs Keycloak (User Storage Provider LDAP/AD) a été basculé vers l'URL sécurisée `ldaps://vm-ad.corp.local:636` :

- La commande de synchronisation globale déclenchée via `kcadm.sh` s'exécute avec succès.
- L'interrogation de l'utilisateur `lab-employee` confirme son rattachement actif à la fédération d'annuaire.
- L'état des connexions système (`ss -tn dst 10.0.20.5:636`) montre une connexion TCP établie :

ESTAB [::ffff:10.0.20.3]:45518 -> [::ffff:10.0.20.5]:636

La règle GCP `zt-allow-keycloak-to-ad` retire TCP 389 sur ce chemin. UDP 389 demeure autorisé pour la découverte d'annuaire. Ce retrait ciblé ne constitue pas un audit de toutes les voies de rétrogradation ou de tous les transports du laboratoire.

Capture privée omise dans cette édition publique ; voir le registre des preuves.

FIGURE 6.17 – Mise à jour du pare-feu GCP : retrait définitif du port TCP 389

Une sonde réseau exécutée immédiatement depuis `vm-keycloak` confirme le résultat :

TCP 389: BLOCKED (PASS)

tandis que la synchronisation LDAPS a été validée fonctionnelle.

6.6 Évaluation de la connectivité hybride et limitations architecturales

Le poste Windows porte le tag `workstation` et l'adresse Tailscale `adresse tailnet masquée`. Le routeur web annonce les réseaux `10.0.20.0/24` et `10.0.99.0/24`. L'inspection du 8 octobre confirme SNAT activé : les cibles VPC voient normalement la source du routeur. Les ACL Tailscale et les règles GCP doivent donc être interprétées ensemble.

La capture fournie le 8 octobre, conservée dans le dossier de preuve de récupération, montre :

- **Portail** : HEAD vers `http://10.0.20.2/` retourne HTTP 200, avec un en-tête Date à 19 :38 :02 UTC. Cela démontre la joignabilité de la racine ; aucun nouveau parcours OIDC authentifié n'est établi par ce test.
- **Base de données** : `Test-NetConnection 10.0.20.4 -Port 5432` retourne False, interface Tailscale et source `adresse tailnet masquée`. Ce test établit la non-joignabilité sur ce chemin ; il ne distingue pas à lui seul refus de politique, problème de routage ou indisponibilité du service.
- **Domaine** : la requête SRV DNS vers `10.0.20.5` expire. La découverte via `nltest` retourne 1355. Il s'agit d'un échec de découverte, pas de la preuve d'une sortie du domaine.
- **SSH** : un refus est rapporté sur le port 22. Le projet prévoit IAP comme chemin d'administration, mais ce refus ne permet pas d'attribuer à lui seul le résultat à une ACL Tailscale ou à une règle GCP précise.

Les premières observations du 8 octobre montrent deux obstacles distincts : la configuration DNS du poste et la politique ingress AD face au routeur SNAT. L'inspection ultérieure confirme que l'autorisation AD a été élargie aux sources Keycloak `10.0.20.3/32` et web/routeur `10.0.20.2/32`, pour TCP 53/88/636 et UDP 53/88/389. Cette exception relâche l'isolation web-AD précédemment testée. Les requêtes DNS dirigées explicitement vers AD réussissent ensuite, mais la résolution par défaut et la découverte du contrôleur restent en échec. Aucune cause unique reliant SNAT, NRPT et continuité du domaine n'est démontrée.

Le 8 octobre 2026, le périmètre technique est gelé. La réparation du split-DNS Windows, de la découverte du domaine et de la continuité d'authentification hybride est reportée aux travaux futurs. Les preuves disponibles distinguent la réussite DNS explicite, l'échec DNS par défaut, l'absence de règle `corp.local` dans la politique NRPT fournie, et les effets d'attribution de source du routeur partagé. Les entrées hosts masquent une partie du symptôme de résolution. Une connexion Kerberos courante et un canal sécurisé fonctionnel ne sont pas établis. Ces limites ne remettent pas en cause les résultats RBAC, SQL et TCP obtenus sur les autres chemins ; elles circonscrivent rigoureusement le périmètre opérationnel de la maquette.

6.7 Discussion critique et synthèse des gains d'ingénierie Zero Trust

6.7.1 Synthèse des contributions réalisées

La contribution ne se limite pas aux tests offensifs : elle comprend la construction initiale sous VMware, la migration de six rôles serveurs vers GCP, le VPC et son socle Terraform, l'administration IAP, l'annuaire et les comptes synthétiques, le portail et ses données, le routage Tailscale, puis l'intégration OIDC/TOTP et le contrôle de rôle. Les configurations Sysmon/Wazuh, l'instrumentation JSON et la règle 100510 rendent certains événements corrélables. Le durcissement complète cet ensemble par cinq tranches ingress, la restriction des privilèges SQL, LDAPS et un test de réponse active synthétique.

La période de juillet à septembre correspond à la construction et à la préparation décrites dans les notes historiques ; les campagnes datées des 6–8 octobre apportent les observations détaillées. Cette distinction évite d'attribuer à une capture récente toute la durée du travail. Le registre de preuves et les limites décrivent ce qui est conservé, ce qui est rapporté et ce qui reste hors validation. Le Terraform conservé décrit le socle initial ; les règles durcies appliquées ensuite ne sont pas toutes codifiées dans ce même état IaC.

6.7.2 Fiabilité opérationnelle et attribution des résultats

Le travail a également porté sur la restauration des dépendances et sur la fiabilité des mesures. Le 7 octobre, le démarrage du gestionnaire Wazuh expire sous systemd alors que certains démons restent présents. Le diagnostic distingue service actif, agents connectés et analyse effective. Une extension de `TimeoutStartSec` à 180 s est suivie d'un démarrage réussi à 20 :14 :03 UTC ; la nécessité de cette extension et la cause complète du démarrage lent ne sont pas établies ; un nouveau refus applicatif est ensuite relié à l'alerte manager et au document indexé. Cette restauration ne prouve pas la continuité de tous les agents, notamment celle du poste Windows.

Le 8 octobre, le portail ne présente plus de listener TCP 80 après arrêt de son unité transitoire. Le source existant est inspecté puis relancé sans debug ni reload ; la racine répond 200 et les routes protégées anonymes répondent 302 à 19 :28 :45 UTC. Cela valide la récupération du service et les gardes anonymes, sans nouveau parcours authentifié. Les preuves sont conservées dans `../../../../evidence/hybrid.mdOBSERVATIONS.md` ; les journaux de récupération Wazuh sont dans `../../../../evidence/rbac.md`.

L'attribution des sondes a été corrigée lorsque le prompt d'une capture montrait `vm-db` malgré une étiquette annonçant une autre source. Les contrôles suivants utilisent une vérification de `hostname`, des horaires UTC et des chemins identifiés. De même, l'audit des droits SQL examine les privilèges effectifs hérités de `PUBLIC`, et pas uniquement les droits directement accordés à `app_user`. Les scripts et observations sont conservés dans `../../../../evidence/database.md`. Ces travaux expliquent comment les résultats ont été rendus défendables.

6.7.3 Limites opérationnelles de l'état gelé

Le 8 octobre, les adresses partagées de Keycloak/proxy et du routeur web (10.0.20.3 et 10.0.20.2) sont exclues du blocage automatique Wazuh. Cette modification limite le risque de couper un chemin partagé, mais réduit aussi la possibilité de confiner individuellement un client masqué par le proxy ou SNAT. Deux blocs de réponse identiques restent configurés. L'expiration effective, la continuité de tous les agents et les effets de ces exclusions ne sont pas mesurés ; les événements 403 et leur alerte doivent être distingués de la décision de blocage. L'inspection est conservée dans `../../../../evidence/hybrid.md` `ANTIGRAVITY_REVIEW.md`.

Le périmètre des règles étudiées est principalement ingress IPv4. Il n'établit pas une politique egress complète, une protection contre l'exfiltration des données lisibles, une restauration éprouvée, ni une équivalence entre le Terraform initial et toutes les mutations du cloud. Les contrôles positifs portent sur des flux et horaires précis ; ils ne constituent pas une mesure de disponibilité continue. Le gel préserve ces limites comme dette documentée.

Les résultats obtenus démontrent l'efficacité concrète du modèle Zero Trust lorsqu'il est articulé de façon multicouche :

- **Au niveau Réseau** : La suppression du réseau plat et l'application de micro-segmentations strictes réduisent la surface d'exposition de 8/8 à 0/8 couples portable TCP face à la source d'attaque étudiée, tout en maintenant les flux métiers autorisés.
- **Au niveau Identité** : Le passage à LDAPS (TLS 1.3) protège les données d'annuaire en transit, tandis que Keycloak et l'application Flask assurent une séparation nette entre authentification (OIDC/TOTP) et autorisation (RBAC).
- **Au niveau Données** : quatre instructions DDL/DML testées sont rejetées sous le rôle applicatif ; les lectures autorisées restent un risque résiduel.
- **Au niveau Détection et Réponse** : les cinq différences événement-alerte manager ont une moyenne de 0,980 s. Le test synthétique de réponse active est distinct de cette mesure ; il ne fournit pas de latence de confinement.

Conclusion

La Phase 4 documente des améliorations complémentaires : réduction de la joignabilité sur une matrice TCP fixe, contrôle RBAC sur la route admin, refus de quatre opérations SQL et transition LDAPS rapportée sur le chemin Keycloak-AD. La réponse active est testée par injection d'un événement synthétique. Ces résultats soutiennent des contrôles précis ; ils ne démontrent ni une intégrité universelle, ni une maîtrise de tous les flux, ni la satisfaction intégrale du NIST SP 800-207.

Conclusion générale

Ce projet a permis de concevoir et d'évaluer un laboratoire d'entreprise sur Google Cloud Platform et VMware, avec des contrôles inspirés du NIST SP 800-207. Les comparaisons disponibles montrent des améliorations sur des périmètres mesurés, sans établir un déploiement Zero Trust complet. La découverte du domaine depuis le poste hybride reste défailante au 8 octobre.

Les campagnes apportent des résultats limités aux chemins observés, avec les réserves suivantes :

1. **Micro-segmentation intra-VPC** : La neutralisation de la règle globale permissive au profit de cinq tranches de moindre privilège a ramené la joignabilité offensive de 8/8 ports à 0/8 ports (chute de 100 % à 0 %), tout en assurant la continuité des échanges inter-serveurs autorisés.
2. **Délimitation du périmètre hybride** : Si la racine du portail applicatif est joignable et l'isolation directe de la base de données confirmée, la résolution DNS par défaut et la découverte du contrôleur échouent sur le chemin hybride. Aucune cause unique NetBIOS, RPC ou SNAT n'est démontrée. Cette observation circonscrit le périmètre opérationnel de la maquette et ouvre la voie aux perspectives d'optimisation via passerelle IPsec ou connecteur Zero Trust natif.
3. **Confinement du rayon d'action (*Blast Radius*)** : Le scénario suppose un accès shell sur vm-web, sans exploitation initiale. Les quatre opérations SQL testées sont rejetées ; SELECT reste autorisé. Les sondes AD du 7 octobre sont historiques, car l'exception routeur du 8 octobre ouvre notamment TCP 88 et 636 depuis vm-web.
4. **Réponse active automatisée** : L'injection d'un événement synthétique pour 198.51.100.99 a entraîné une exécution `firewall-drop` rapportée et une insertion DROP rapportée. Elle établit le déclenchement sur ce scénario ; aucun trafic adverse réel, délai de confinement ou expiration effective n'est mesuré.
5. **Durcissement cryptographique de l'identité** : La transition vers LDAPS en TLS 1.3 (suite TLS_AES_256_GCM_SHA384) et le retrait du port en clair 389 sur la règle pare-feu dédiée ont sécurisé la fédération d'annuaire.

Les essais montrent une réduction de la joignabilité de 8/8 à 0/8 couples cible-port TCP depuis la source attaquante étudiée, un refus de la route administrateur pour le compte employé, et le rejet de quatre opérations SQL sous le rôle applicatif. Ces résultats caractérisent rigoureusement les chemins testés et ne constituent pas une garantie globale

d'invulnérabilité. Ce projet démontre qu'une architecture Zero Trust ne se résume pas à un produit unique, mais constitue une rigoureuse stratégie d'ingénierie combinant réseau, identité, moindres privilèges applicatifs et supervision active pour protéger efficacement le système d'information moderne face aux menaces avancées.

Bibliographie

- [1] S. Rose, O. Borchert, S. Mitchell et S. Connelly, *Zero Trust Architecture*, NIST SP 800-207, août 2020. <https://doi.org/10.6028/NIST.SP.800-207>.
- [2] Microsoft, *Active Directory Domain Services overview*. <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/virtual-dc/active-directory-domain-services-overview>.
- [3] OpenID Foundation, *OpenID Connect Core 1.0 incorporating errata set 2*. https://openid.net/specs/openid-connect-core-1_0.html.
- [4] Keycloak, *Server Administration Guide*, fédération LDAP, rôles et authentification. https://www.keycloak.org/docs/latest/server_admin/index.html.
- [5] Google Cloud, *VPC firewall rules*. <https://docs.cloud.google.com/firewall/docs/firewalls>.
- [6] Tailscale, *Subnet routers*. <https://tailscale.com/docs/features/subnet-routers>.
- [7] Google Cloud, *Use IAP for TCP forwarding*. <https://docs.cloud.google.com/iap/docs/using-tcp-forwarding>.
- [8] M. Russinovich et T. Garnier, Microsoft Sysinternals, *Sysmon*. <https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>.
- [9] Wazuh, *Architecture – Getting started*. <https://documentation.wazuh.com/current/getting-started/architecture.html>.
- [10] PostgreSQL Global Development Group, *The pg_hba.conf File*. <https://www.postgresql.org/docs/current/auth-pg-hba-conf.html>.
- [11] MITRE, *ATT&CK Knowledge Base*. <https://attack.mitre.org/>.
- [12] HashiCorp, *What is Terraform ?*. <https://developer.hashicorp.com/terraform/intro>.
- [13] Microsoft, *Configure firewall for Active Directory domains and trusts*. Consulté le 8 octobre 2026. <https://learn.microsoft.com/en-us/troubleshoot/windows-server/active-directory/config-firewall-for-ad-domains-and-trusts>.
- [14] Tailscale, *Disable subnet route masquerading*. Consulté le 8 octobre 2026. <https://tailscale.com/docs/reference/troubleshooting/network-configuration/disable-subnet-route-masquerading>.
- [15] Wazuh, *Active Response : additional information*. Consulté le 8 octobre 2026. <https://documentation.wazuh.com/current/user-manual/capabilities/active-response/additional-information.html>.

- [16] Cybersecurity and Infrastructure Security Agency (CISA), *Zero Trust Maturity Model Version 2.0*, Cybersecurity Division, avril 2023. <https://www.cisa.gov/zero-trust-maturity-model>.
- [17] Department of Defense (DoD), *Department of Defense Zero Trust Reference Architecture Version 2.0*, Defense Information Systems Agency (DISA), juillet 2022.
- [18] V. C. Hu, D. Ferraiolo, R. Kuhn et al., *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*, NIST Special Publication 800-162, janvier 2014. <https://doi.org/10.6028/NIST.SP.800-162>.
- [19] J. H. Saltzer et M. D. Schroeder, *The Protection of Information in Computer Systems*, Proceedings of the IEEE, vol. 63, no. 9, p. 1278–1308, septembre 1975. <https://doi.org/10.1109/PROC.1975.9939>.
- [20] E. Rescorla, *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 8446, Internet Engineering Task Force (IETF), août 2018. <https://doi.org/10.17487/RFC8446>.
- [21] M. Jones, J. Bradley et N. Sakimura, *JSON Web Token (JWT)*, RFC 7519, Internet Engineering Task Force (IETF), mai 2015. <https://doi.org/10.17487/RFC7519>.
- [22] D. M’Raihi, S. Machani, M. Pei et J. Rydell, *TOTP : Time-Based One-Time Password Algorithm*, RFC 6238, Internet Engineering Task Force (IETF), mai 2011. <https://doi.org/10.17487/RFC6238>.
- [23] J. Sermersheim, *Lightweight Directory Access Protocol (LDAP) : The Protocol*, RFC 4511, Internet Engineering Task Force (IETF), juin 2006. <https://doi.org/10.17487/RFC4511>.
- [24] National Institute of Standards and Technology, *Security and Privacy Controls for Information Systems and Organizations*, NIST SP 800-53 Rev. 5, septembre 2020. <https://doi.org/10.6028/NIST.SP.800-53r5>.
- [25] J. A. Donenfeld, *WireGuard : Next Generation Kernel Network Tunnel*, Proceedings of the Network and Distributed System Security Symposium (NDSS 2017), février 2017. <https://doi.org/10.14722/ndss.2017.23160>.

Les références initiales portent une consultation au 3 octobre 2026 ; les références de réparation ont été vérifiées le 8 octobre. Les ajouts NIST et LDAPS ont été confrontés aux sources primaires lors de l’audit documentaire du 9 octobre. Les versions documentaires ne constituent pas une preuve des versions installées.

Annexe A

Cahier de recette et guide de reproduction

Cette annexe relie les résultats aux traces disponibles et aux procédures de recette. Elle distingue preuves conservées, résultats rapportés et vérifications encore ouvertes. La reproduction complète et la restauration des sauvegardes ne sont pas démontrées.

A.1 Registre des preuves de l'édition publique

Les résumés suivants sont inclus sous **evidence/** dans le dépôt. Ils documentent la provenance et les limites des résultats ; les captures privées et les traces brutes non autorisées à la diffusion ne sont pas intégrées à ce PDF.

Résultat et preuve	Portée et limites
RBAC	Employé refusé sur /admin, compte de test autorisé admis ; routes et chemin observés.
Détection Wazuh	Cinq paires événement-alerte ; échantillon descriptif, sans taux global ni délai de confinement.
Segmentation réseau	Huit couples TCP ciblés, source vm-attacker et chemin VPC ; résultat borné à la matrice testée.
Privilèges greSQL	Post- Lectures applicatives conservées et opérations non autorisées refusées ; SELECT reste permis.
Campagnes rieures	ulté- Réponse active synthétique et LDAPS rapportés ; les traces brutes complètes ne sont pas publiées.
Limitation hybride	Accès portail/base et découverte du domaine documentés ; la continuité Windows reste non résolue.

A.2 Limites et recette de la réparation proposée

Le routeur applique SNAT [14]. L'exception AD inspectée admet maintenant le routeur web et Keycloak pour les services sélectionnés. Cette évolution est décrite dans la section hybride ; elle n'établit ni jonction courante, ni continuité complète du domaine. Les besoins RPC, stratégie de groupe et changement de mot de passe restent des travaux futurs [13]. Les recettes de réparation historiques ne sont pas des commandes exécutées ni des prérequis de livraison après gel du périmètre.

En cas de reouverture explicite du périmètre, vérifier séparément résolution SRV, découverte du contrôleur, ticket Kerberos, parcours du portail, contrôles négatifs et événements Windows. Les exclusions des sources partagées ont été inspectées après modification externe, mais deux blocs de réponse identiques persistent. Leur suppression et la vérification d'expiration restent des travaux futurs, pas des changements réalisés dans cette édition. Sources HTTP/OIDC, posture du terminal, reévaluation continue, assurance du transport DB et restauration restent des limites du laboratoire.

A.3 État opérationnel à la clôture du périmètre

Le 9 octobre 2026, l'utilisateur a indiqué que les six VM GCP avaient été arrêtées. Cet état n'a pas été interrogé directement dans la console pendant la préparation de cette édition. La reprise des services est hors du périmètre gelé ; les séquences de démarrage historiques ne sont donc pas présentées comme une procédure de reproduction vérifiée.

L'arrêt des VM réduit les coûts de calcul, sans établir un coût nul : disques persistants, instantanés, adresses réservées et autres ressources conservées peuvent continuer à être facturés. L'état de facturation et les ressources résiduelles n'ont pas été audités ici. Aucune modification cloud n'a été effectuée pour produire cette édition portfolio.